



Unidad Didáctica

Antecedentes y Entorno de la Auditoría en Tecnologías de Información, Unidad I

Índice de Contenido

Contenido

Introducción	3
Desarrollo de Contenidos	4
Conceptos Generales.....	4
Antecedentes y Orígenes de la Auditoría.....	13
Tipos de Auditorías	23
Control Interno y Auditoría de TI	42
Características y Funciones del Auditor de TI	57
Modelos, Normas y Estándares de Seguridad Informática y su Relación con la Auditoría de TI.....	74
Bibliografía y Webgrafía	75
Glosario	75

En la era digital actual, donde la información se ha convertido en uno de los activos más valiosos de las organizaciones, la función de la Auditoría en Tecnologías de Información (TI) emerge como un pilar fundamental para garantizar la integridad, confidencialidad y disponibilidad de los datos. Esta primera unidad, titulada "Antecedentes y Entorno de la Auditoría en Tecnologías de Información", sienta las bases conceptuales y contextuales necesarias para comprender la importancia y el alcance de esta disciplina.

A lo largo de este módulo, exploraremos el origen y la evolución de la auditoría, desde sus enfoques tradicionales hasta su especialización en el ámbito tecnológico. El objetivo es que el estudiante no solo conozca los diferentes tipos de auditoría que existen, sino que también sea capaz de analizar el entorno del negocio, las mejores prácticas y las regulaciones que rigen su aplicación en la actualidad.

Se abordarán los conceptos de control interno y su relación directa con la auditoría de TI, así como las características, funciones y objetivos que definen el rol del auditor de TI en una organización. Asimismo, se realizará un recorrido por los principales modelos, normas y estándares de seguridad informática, comprendiendo cómo estos marcos se convierten en herramientas esenciales para el ejercicio de la auditoría.

Al finalizar esta unidad, el estudiante estará en capacidad de identificar el contexto en el que se desenvuelve la auditoría de TI y apreciar su valor estratégico como mecanismo de control y aseguramiento de la información en cualquier tipo de organización.

Conceptos Generales

Para adentrarnos en el mundo de la Auditoría en Tecnologías de Información, debemos primero construir una base sólida de conceptos fundamentales. Así como un arquitecto no puede diseñar un edificio sin conocer las propiedades del cemento y el acero, un auditor de TI no puede evaluar sistemas sin comprender qué es la auditoría, qué son las TI y cómo se entrelazan estos conceptos. En este tema, exploraremos estas definiciones esenciales y estableceremos el lenguaje común que utilizaremos a lo largo de toda la asignatura.

¿Qué es la Auditoría?

Origen etimológico e histórico

La palabra auditoría proviene del latín audire, que significa "oír". Este origen se remonta a la antigüedad, cuando los responsables de la administración de bienes y recursos en imperios como el romano o en las ciudades-estado griegas rendían cuentas de su gestión de forma verbal. Los "auditores" de aquella época eran personas designadas para escuchar estos informes y emitir un juicio sobre su veracidad y exactitud.

Con el paso de los siglos, especialmente con la Revolución Industrial y el surgimiento de las grandes corporaciones, la necesidad de verificación se volvió más compleja. La información financiera ya no podía transmitirse oralmente; comenzó a documentarse en registros contables. Así, la auditoría evolucionó de "escuchar" a "examinar, verificar y evaluar" registros, procedimientos y estados financieros para emitir una opinión profesional e imparcial.

Definición moderna de Auditoría

En la actualidad, la auditoría se define como un proceso sistemático, objetivo e independiente que consiste en obtener y evaluar evidencias para determinar si las actividades, eventos, procesos o información de una entidad cumplen con criterios, normas o requisitos establecidos. El resultado de este proceso es un informe que comunica los hallazgos y conclusiones a las partes interesadas.

Elementos clave de esta definición:

- **Proceso sistemático:** No es una revisión al azar. Sigue una metodología, pasos y procedimientos predefinidos.
- **Objetivo e independiente:** El auditor debe ser imparcial y no tener conflictos de interés con lo que está auditando. Su juicio debe basarse en hechos y evidencias, no en opiniones personales o presiones.
- **Evidencias:** Son los hechos, documentos, registros, entrevistas y cualquier información que respalde las conclusiones del auditor.
- **Criterios establecidos:** Son las normas, leyes, estándares o políticas contra las cuales se compara la evidencia. Por ejemplo, para una auditoría financiera, el criterio son las Normas Internacionales de Información Financiera (NIIF). Para una auditoría de seguridad, podría ser la norma ISO 27001.

¿Qué son las Tecnologías de Información (TI)?

Las Tecnologías de Información (TI) son el conjunto de recursos, herramientas, equipos, programas informáticos, aplicaciones, redes y medios empleados para la recopilación, procesamiento, almacenamiento, transmisión y protección de la información .

Imaginemos una empresa como un cuerpo humano:

- El Hardware (servidores, computadoras, cables) sería el esqueleto y los órganos.
- El Software (sistemas operativos, aplicaciones como SAP, Oracle, o incluso Excel) sería el sistema nervioso y el cerebro, que da instrucciones y procesa la información.
- Los Datos (información de clientes, transacciones financieras, inventarios) serían la sangre, que fluye por todo el cuerpo y es vital para la vida.
- Las Redes (internet, intranet) serían las venas y arterias, que permiten que la sangre (datos) fluya a donde se necesita.
- El Talento Humano (administradores de red, programadores, usuarios) sería la conciencia que opera y da propósito al cuerpo.
- El objetivo principal de las TI es apoyar y optimizar los procesos de una organización para alcanzar sus metas estratégicas, ya sea aumentando la eficiencia, mejorando la toma de decisiones o creando ventajas competitivas.

Definición de Auditoría en TI (o Auditoría Informática)

Al unir los dos conceptos anteriores, obtenemos la definición de Auditoría en Tecnologías de Información. Es el proceso de revisión y evaluación sistemática del entorno de TI de una organización (hardware, software, redes, datos, personal y procedimientos) para verificar que:

- Protege la integridad de los datos: La información es precisa, completa y no ha sido modificada sin autorización.
- Cumple con los protocolos y normativas establecidas: Sigue las políticas internas de la empresa y las leyes externas aplicables (como la Ley de Protección de Datos Personales en Nicaragua, o regulaciones bancarias).
- Hace un uso eficiente de los recursos: Los activos tecnológicos se utilizan de manera óptima, sin duplicidades ni desperdicios.
- Alinea la tecnología con los objetivos del negocio: La infraestructura y los sistemas de TI realmente apoyan a la empresa a cumplir su misión y metas .
- Garantiza la seguridad de la información: Asegura la confidencialidad (solo quienes deben, acceden), integridad (datos confiables) y disponibilidad (la información y sistemas están operativos cuando se necesitan) de los activos de información.

Ejemplo:

Imaginemos BAC Credomatic Nicaragua, una de las instituciones financieras más grandes del país. Una auditoría de TI en esta entidad no solo revisaría que los servidores estén funcionando. Evaluaría si el sistema de banca en línea protege adecuadamente los datos de miles de clientes (confidencialidad), si las transacciones registradas en las aplicaciones coinciden exactamente con los movimientos financieros (integridad), y si el sistema de tarjetas de crédito/débito tiene la capacidad de procesar miles de transacciones por minuto sin caerse, especialmente en fechas de alto consumo como Black Friday o Navidad (disponibilidad).

Características Principales de la Auditoría de TI

La auditoría de TI tiene características muy particulares que la diferencian de otros tipos de auditoría:

- Alto componente técnico: El auditor no solo debe saber de auditoría, debe tener sólidos conocimientos en redes, bases de datos, sistemas operativos, programación y seguridad informática.
- Enfoque en el riesgo: Se centra en identificar y evaluar los riesgos tecnológicos que pueden afectar el negocio (riesgo de ciberataques, riesgo de pérdida de información, riesgo de fallas operativas).
- Visión integral: No evalúa la tecnología de forma aislada, sino en su interacción con los procesos de negocio y las personas.
- Actualización constante: La tecnología cambia rápidamente (cloud computing, inteligencia artificial, blockchain). El auditor de TI debe estar en continuo aprendizaje para poder auditar las nuevas tecnologías.
- Uso de herramientas automatizadas: A diferencia de otras auditorías, la de TI se apoya fuertemente en software especializado para analizar grandes volúmenes de datos, escanear vulnerabilidades en redes o verificar configuraciones de sistemas.

Objetivos Fundamentales de la Auditoría de TI

Los objetivos pueden agruparse en tres grandes categorías, conocidas como el modelo CIA (por sus siglas en inglés: Confidentiality, Integrity, Availability), que es la base de la seguridad de la información:

OBJETIVO	DESCRIPCIÓN	EJEMPLO EN EL CONTEXTO NICARAGÜENSE
CONFIDENCIALIDAD	Garantizar que la información no sea accesible ni revelada a personas, entidades o procesos no autorizados.	En una aseguradora como INISER , la auditoría debe verificar que solo los agentes autorizados puedan acceder a las pólizas y datos médicos de los asegurados, y no cualquier empleado.
INTEGRIDAD	Salvaguardar la exactitud y completez de la información y los métodos de procesamiento.	En la Alcaldía de Managua , una auditoría revisaría que el sistema de recaudación de impuestos municipales registre correctamente cada pago, sin que los montos puedan ser modificados por un funcionario sin dejar una traza o evidencia.
DISPONIBILIDAD	Asegurar que los usuarios autorizados tengan acceso a la información y los activos relacionados cuando lo requieran.	Para BANPRO , la disponibilidad de su aplicación móvil y banca en línea es crítica. Una auditoría evaluaría si la infraestructura tiene la capacidad de soportar un aumento masivo de transacciones y si existen planes de recuperación ante desastres en caso de un fallo mayor.

Además de estos tres pilares, la auditoría de TI también persigue objetivos como:

- **Cumplimiento:** Verificar la adherencia a leyes y normativas. Por ejemplo, las Normas de Auditoría Gubernamental de Nicaragua (NAGUN) para una entidad pública como el MINSA, o el cumplimiento de estándares de seguridad para tarjetas de pago (PCI DSS) para un comercio que acepta tarjetas de crédito, como La Colonia.
- **Eficiencia:** Evaluar si los recursos de TI se utilizan de la mejor manera. Por ejemplo, detectar servidores infrautilizados que podrían consolidarse para ahorrar costos de energía y mantenimiento.

- Eficacia: Determinar si los sistemas de TI realmente apoyan el logro de los objetivos del negocio. Por ejemplo, ¿el nuevo sistema de gestión implementado en la Empresa Nicaragüense de Telecomunicaciones (TELCOR) ha mejorado realmente la velocidad de atención al cliente?

Beneficios de Implementar Auditorías de TI

Realizar auditorías de TI de forma regular aporta beneficios tangibles a cualquier organización:

- Prevención de fraudes y ciberataques: Identifica vulnerabilidades antes de que sean explotadas.
- Ahorro de costos: Al detectar software sin licencia (evitando multas), hardware obsoleto o redundancias.
- Mejora de la reputación: Demuestra a clientes y socios que la organización se toma en serio la seguridad y el buen gobierno de la información.
- Toma de decisiones informada: Proporciona a la alta dirección un diagnóstico claro del estado de la tecnología, lo que permite invertir de forma más inteligente.
- Continuidad del negocio: Ayuda a garantizar que la empresa pueda seguir operando incluso después de un incidente grave, como un ataque de ransomware o un desastre natural.

Autoevaluación

A continuación, responde las siguientes preguntas para verificar tu comprensión de los conceptos fundamentales. Revisa tus apuntes y el material antes de comenzar .

Pregunta 1:

El término "auditoría" proviene del latín audire, que significa:

- a) Escribir
- b) Verificar
- c) Oír
- d) Calcular

Pregunta 2:

¿Cuál de las siguientes opciones describe MEJOR el concepto de Tecnologías de Información (TI)?

- a) Únicamente las computadoras y servidores de una empresa.
- b) El conjunto de recursos, herramientas y medios para gestionar información, incluyendo hardware, software, datos, redes y personas.
- c) Exclusivamente el software y las aplicaciones que usa una organización.
- d) Los datos y la información que posee una compañía.

Pregunta 3:

En el modelo CIA de la seguridad de la información, la letra "I" representa:

- a) Información
- b) Independencia
- c) Integridad
- d) Investigación

Pregunta 4:

Una auditoría de TI que verifica si una entidad pública nicaragüense cumple con las NAGUN es un ejemplo de objetivo de:

- a) Eficiencia
- b) Disponibilidad
- c) Confidencialidad
- d) Cumplimiento

Pregunta 5 (Caso Práctico):

Imagina que trabajas en una empresa nicaragüense de comercio electrónico (como Yamatú) y se realiza una auditoría de TI. El auditor descubre que, en horas pico, los clientes no pueden completar sus compras porque el sitio web se cae. ¿Qué principio fundamental de la seguridad de la información se está viendo directamente afectado?

- a) Confidencialidad
- b) Integridad
- c) Disponibilidad
- d) Cumplimiento

Antecedentes y Orígenes de la Auditoría

Para comprender plenamente la Auditoría en Tecnologías de Información, es esencial conocer su genealogía. No surge de la nada; es el resultado de una evolución natural de la auditoría tradicional, impulsada por la creciente informatización de la sociedad y las organizaciones. Así como la medicina moderna no se entiende sin los conocimientos de la anatomía y fisiología básicas, la auditoría de TI se asienta sobre los principios de la auditoría clásica, pero adaptada a un entorno digital. Este tema nos llevará por un viaje a través del tiempo, desde los primeros registros contables en tablillas de arcilla hasta los complejos sistemas interconectados de la era digital, destacando los hitos que hicieron necesaria la figura del auditor de TI.

Evolución Histórica de la Auditoría: De lo Tradicional a lo Informático

Los albores de la auditoría: control y rendición de cuentas

La necesidad de controlar los recursos no es nueva. Desde las primeras civilizaciones, los gobernantes y comerciantes buscaron mecanismos para verificar que lo que se poseía o administraba coincidiera con lo registrado.

- Antigüedad (Mesopotamia, Egipto, Roma): Se han encontrado registros en tablillas de arcilla que evidencian un control de cosechas, tributos y bienes. En el Imperio Romano, los cuestores eran funcionarios encargados de la administración financiera y rendían cuentas ante el Senado. La palabra auditor ya se usaba para designar a quienes "oían" esas rendiciones.
- Edad Media: Con el feudalismo, los señores feudales requerían controlar la producción de sus tierras. Los monasterios también llevaban minuciosos registros de sus posesiones y diezmos.
- Revolución Industrial (siglos XVIII y XIX): El surgimiento de grandes fábricas y corporaciones, junto con la separación entre la propiedad (accionistas) y la gestión (directivos), generó una necesidad imperiosa de contar con

información fiable sobre la marcha de los negocios. Los inversores querían saber si su dinero se estaba utilizando correctamente. Así nace la auditoría financiera moderna, con firmas especializadas que revisaban los estados contables y emitían una opinión independiente.

La era de la informatización (1950-1980): el germen de la auditoría de TI

La aparición de las primeras computadoras comerciales en la década de 1950 cambió radicalmente la forma de procesar la información. Inicialmente, los grandes ordenadores (mainframes) eran utilizados por grandes empresas y gobiernos para tareas masivas como nóminas, contabilidad y gestión de inventarios.

- Auditoría "alrededor" del ordenador: En esta primera etapa, los auditores financieros, que aún no tenían conocimientos informáticos, optaban por auditar alrededor del ordenador. Es decir, verificaban los datos de entrada (inputs) y comparaban los resultados impresos (outputs) con los documentos fuente. Asumían que si los datos de entrada eran correctos y los resultados coincidían, el procesamiento interno (la "caja negra" de la computadora) también debía ser correcto. Este enfoque era posible porque los sistemas eran centralizados y la información solía imprimirse en listados.
- Auditoría "a través" del ordenador: A medida que los sistemas se volvieron más complejos y se redujo el uso de papel, el enfoque anterior se volvió insuficiente. Los auditores comenzaron a darse cuenta de que necesitaban entender qué pasaba dentro del ordenador. Surgió entonces la necesidad de auditar a través del ordenador, utilizando programas informáticos para probar los controles internos del sistema, verificar la lógica de procesamiento y analizar los datos almacenados. Este fue el verdadero nacimiento de la auditoría de TI.

Hitos que marcaron el desarrollo de la auditoría de TI

Diversos eventos y necesidades impulsaron la consolidación de esta disciplina:

HITO / PERÍODO	DESCRIPCIÓN	IMPACTO EN LA AUDITORÍA DE TI
DÉCADA DE 1960	Surgen los primeros fraudes informáticos conocidos. Por ejemplo, empleados que modificaban programas para desviar pequeñas cantidades de dinero a cuentas propias (técnica conocida como "técnica del salami").	Se evidencia que los sistemas pueden ser manipulados y que los controles tradicionales no son suficientes. Se empieza a hablar de "control interno en sistemas".
DÉCADA DE 1970	Creación de la Asociación de Auditoría y Control de Sistemas de Información (ISACA) en 1969 por un grupo de auditores que reconocían la necesidad de estandarizar y profesionalizar la auditoría de sistemas.	ISACA desarrolla y publica estándares, guías y procedimientos para la auditoría de TI. En 1978, introduce la designación CISA (Certified Information Systems Auditor) , que se convierte en la certificación de referencia mundial para auditores de TI.
DÉCADA DE 1980	Masificación de las computadoras personales (PC) y las redes locales. Los sistemas dejan de ser centralizados y la información se distribuye. Aparecen los primeros virus informáticos.	La auditoría de TI debe ahora considerar entornos distribuidos, la seguridad en redes y la proliferación de software no controlado. Se hace necesario auditar no solo los mainframes, sino también los servidores y las estaciones de trabajo.
DÉCADA DE 1990	Expansión de Internet y el comercio electrónico. Las empresas se conectan globalmente. Surgen preocupaciones sobre la seguridad de las transacciones en línea y la privacidad de los datos. Aparecen estándares como COBIT (Objetivos de Control para Información y Tecnologías relacionadas) publicado por ISACA en 1996.	COBIT proporciona un marco de trabajo integral que vincula los objetivos de control de TI con los objetivos del negocio. Se convierte en la herramienta fundamental para los auditores de TI, permitiéndoles evaluar no solo la seguridad, sino también la eficacia y eficiencia de TI.
AÑOS 2000	Estallido de la burbuja punto com. Fraudes corporativos como Enron y WorldCom, que llevan a la creación de la ley Sarbanes-Oxley (SOX) en Estados Unidos (2002).	SOX exige a las empresas que cotizan en bolsa implementar controles internos robustos sobre la información financiera, incluyendo los sistemas de TI que la procesan. Esto dispara la demanda de auditores de TI, ya que deben

		evaluar los controles generales y de aplicación de los sistemas que soportan los reportes financieros.
AÑOS 2010- PRESENTE	Auge de la computación en la nube, el big data, el Internet de las Cosas (IoT), la inteligencia artificial y el incremento exponencial de los ciberataques (ransomware, phishing, APT).	La auditoría de TI se enfrenta a nuevos desafíos: auditar entornos virtualizados y en la nube (sin control físico de los activos), evaluar algoritmos de IA, analizar inmensos volúmenes de datos, y verificar la resiliencia de las organizaciones ante ciberamenazas cada vez más sofisticadas

El Contexto Nicaragüense: La Evolución de la Auditoría de TI en el País

Nicaragua no ha estado ajena a esta evolución global, aunque con un ritmo y características propias, marcadas por el desarrollo económico, la modernización del Estado y la penetración de las tecnologías.

Década de 1980: Los inicios de la informatización

Durante la década de 1980, en Nicaragua, el uso de computadoras era incipiente y limitado a grandes instituciones estatales, universidades y algunas empresas privadas. Se utilizaban principalmente mainframes y minicomputadoras para tareas administrativas básicas. En este período, no existía una práctica formal de auditoría de TI; las revisiones se centraban en los aspectos financieros y, a lo sumo, se hacían arqueos de caja y verificación de documentos impresos.

Década de 1990: Apertura económica y modernización

Con los gobiernos de turno y las políticas de apertura económica, el país experimentó una mayor inversión extranjera y la llegada de nuevas tecnologías. La banca privada se expandió y comenzó a modernizar sus sistemas. Empresas como BANIC (luego

parte del Grupo Promerica) y Banco de América Central (BAC) iniciaron procesos de automatización más profundos.

Surgieron los primeros cajeros automáticos en el país, lo que implicaba nuevos riesgos y la necesidad de controles sobre las redes y las transacciones electrónicas.

La Contraloría General de la República (CGR), como ente rector del control gubernamental, empezó a incluir en sus auditorías revisiones a los sistemas informáticos de las entidades públicas, aunque aún de manera incipiente y sin metodologías especializadas.

En 1997, Nicaragua aprueba la Ley 290, Ley de Organización, Competencia y Procedimientos del Poder Ejecutivo, que impulsa la modernización del Estado y el uso de tecnologías en la administración pública.

Década de 2000: Profesionalización y primeras regulaciones

La entrada en vigor de tratados comerciales como el DR-CAFTA (2006) y la creciente inversión en zonas francas y telecomunicaciones exigieron mayores estándares de control y transparencia.

Las firmas de auditoría internacional (Big Four: Deloitte, PwC, EY, KPMG) con presencia en la región comenzaron a ofrecer servicios de auditoría de TI en Nicaragua, formando a los primeros profesionales con certificaciones como CISA.

La Superintendencia de Bancos y de Otras Instituciones Financieras (SIBOIF) emitió normas que obligaban a las entidades financieras a contar con controles internos y auditorías sobre sus sistemas de información, dado el riesgo sistémico que representan.

En el sector público, la CGR actualizó sus Normas de Auditoría Gubernamental (NAGUN), incorporando lineamientos para la auditoría de sistemas de información y seguridad informática.

Década de 2010 a la actualidad: Ciberseguridad y cumplimiento normativo

Hoy, Nicaragua vive una realidad digital similar a la de muchos países de la región, con desafíos importantes:

- Banca y microfinanzas: Instituciones como BANPRO, BAC, FICOHSA y numerosas microfinancieras (ej. FUNDENUSE, FDL) dependen completamente de sus plataformas tecnológicas. La auditoría de TI es vital para garantizar la continuidad del negocio y la confianza de los depositantes.
- Gobierno Electrónico: El gobierno ha impulsado iniciativas como el Sistema de Administración Financiera Integrado (SAFI) , la factura electrónica (implementada por la Dirección General de Ingresos - DGI), y el carnet de vacunación digital. Estos proyectos requieren auditorías que verifiquen la integridad de los datos fiscales y la protección de la información personal de los ciudadanos.
- Sector privado: Empresas como Claro Nicaragua y Tigo (telecomunicaciones), La Colonia y Palí (retail), y el sector de zonas francas (textiles, servicios BPO) necesitan auditar sus sistemas para cumplir con estándares internacionales (PCI DSS para pagos con tarjeta, ISO 27001, etc.).
- Marco legal: En 2020 se aprobó la Ley No. 1042, Ley de Protección de Datos Personales, que establece obligaciones para las empresas sobre el tratamiento de datos personales. Esto ha creado una nueva área de trabajo para los auditores de TI, quienes deben verificar el cumplimiento de esta normativa.

Factores que Impulsaron el Surgimiento y Desarrollo de la Auditoría de TI

Podemos resumir en varios factores clave las causas que hicieron indispensable la auditoría de TI:

- Dependencia tecnológica: Las organizaciones ya no pueden funcionar sin sus sistemas. Una caída de una hora puede significar pérdidas millonarias. Es necesario auditar la disponibilidad y la continuidad.
- Riesgos informáticos crecientes: Virus, hackers, fraudes internos, errores de programación, desastres naturales. La auditoría identifica y evalúa estos riesgos.
- Requerimientos legales y normativos: Leyes como SOX, Basilea (para bancos), PCI DSS, protección de datos, y las locales (NAGUN, regulaciones SIBOIF) exigen controles específicos sobre TI.
- Complejidad de los sistemas: Los entornos actuales son heterogéneos (múltiples plataformas, aplicaciones, bases de datos), lo que dificulta el control sin una revisión especializada.
- Valor de la información: Los datos se han convertido en el activo más importante. Proteger su confidencialidad, integridad y disponibilidad es misión de la auditoría de TI.
- Necesidad de alinear TI con el negocio: La alta dirección necesita saber si la inversión en tecnología realmente está aportando valor y ayudando a cumplir los objetivos estratégicos.

Los antecedentes de la auditoría de TI nos muestran que no es una moda pasajera, sino una respuesta evolutiva a los cambios en el entorno empresarial y tecnológico. Desde la simple verificación de documentos en la antigüedad hasta la compleja evaluación de algoritmos de inteligencia artificial hoy, el principio subyacente sigue siendo el mismo: generar confianza a través de la verificación independiente. En Nicaragua, esta disciplina ha ido ganando terreno impulsada por la modernización del Estado, la sofisticación del sector financiero y la creciente conciencia sobre la ciberseguridad. Comprender este recorrido histórico nos permite apreciar la importancia estratégica del auditor de TI en el mundo contemporáneo.

Autoevaluación

Responde las siguientes preguntas para verificar tu comprensión sobre los antecedentes y orígenes de la auditoría.

Pregunta 1:

En los inicios de la computación, los auditores financieros solían auditar "alrededor del ordenador". ¿En qué consistía este enfoque?

- a) En revisar el código fuente de los programas para verificar su lógica.
- b) En verificar los datos de entrada y los resultados impresos, asumiendo que el procesamiento interno era correcto.
- c) En utilizar software especializado para analizar las bases de datos.
- d) En auditar únicamente el hardware y las instalaciones físicas.

Pregunta 2:

¿Qué organización internacional, fundada en 1969, es la principal referente en el desarrollo de estándares y certificaciones para la auditoría de TI (como CISA)?

- a) IEEE
- b) ISO
- c) ISACA
- d) AICPA

Pregunta 3:

La ley Sarbanes-Oxley (SOX), surgida tras los fraudes de Enron y WorldCom, impulsó fuertemente la auditoría de TI porque:

- a) Prohíbe el uso de computadoras en los reportes financieros.
- b) Exige que las empresas coticen en bolsa.
- c) Requiere que las empresas implementen y evalúen controles internos sobre la información financiera, incluyendo los sistemas de TI.
- d) Crea la figura del auditor de TI en todos los países.

Pregunta 4:

En el contexto nicaragüense, ¿cuál de las siguientes entidades ha jugado un papel clave en la regulación de la auditoría de TI en el sector público, a través de normas como las NAGUN?

- a) Banco Central de Nicaragua (BCN)
- b) Superintendencia de Bancos (SIBOIF)
- c) Contraloría General de la República (CGR)
- d) Cámara de Comercio de Nicaragua

Pregunta 5:

¿Cuál de los siguientes NO es un factor que impulsó el surgimiento de la auditoría de TI?

- a) La creciente dependencia de las organizaciones de sus sistemas informáticos.
- b) La disminución de los ciberataques y fraudes informáticos.
- c) La complejidad de los entornos tecnológicos actuales.
- d) La necesidad de cumplir con leyes de protección de datos personales.

Tipos de Auditorías

Cuando hablamos de auditoría en el ámbito de las Tecnologías de Información, no nos referimos a una única disciplina homogénea, sino a un conjunto de especializaciones que abordan diferentes aspectos del complejo mundo tecnológico. Así como en la medicina existen cardiólogos, neurólogos y pediatras, en la auditoría de TI encontramos profesionales que se enfocan en seguridad, otros en sistemas específicos, otros en proyectos, y así sucesivamente.

Para un futuro auditor de TI, comprender esta clasificación es fundamental, ya que le permitirá identificar su área de especialización, entender el alcance de los trabajos que se le encomienden y reconocer cuándo necesita apoyarse en otros especialistas. En este tema, exploraremos en profundidad los diferentes tipos de auditoría relacionados exclusivamente con TIC, sus objetivos, metodologías y aplicaciones prácticas en el contexto de las organizaciones nicaragüenses.

Clasificación de la Auditoría en Tecnologías de Información

flowchart TD

A[AUDITORÍA EN TECNOLOGÍAS
DE INFORMACIÓN] --> B[Según el Objeto de Revisión]

A --> C[Según el Enfoque o Alcance]

A --> D[Según el Momento de Realización]

B --> B1[Auditoría de Seguridad Informática]

B --> B2[Auditoría de Sistemas o Aplicaciones]

B --> B3[Auditoría de Infraestructura Tecnológica]

B --> B4[Auditoría de Bases de Datos]

B --> B5[Auditoría de Redes y Comunicaciones]

B --> B6[Auditoría de Proyectos TI]

C --> C1[Auditoría de Gobierno de TI]

C --> C2[Auditoría de Continuidad del Negocio]

C --> C3[Auditoría de Cumplimiento Normativo en TI]

C --> C4[Auditoría de Calidad de Software]

C --> C5[Auditoría Forense Informática]

D --> D1[Auditoría Preventiva]

D --> D2[Auditoría Detectiva]

D --> D3[Auditoría Correctiva]

Tipos de Auditoría de TI según el Objeto de Revisión

Esta clasificación atiende al qué se audita: el componente tecnológico específico que es sometido a examen.

Auditoría de Seguridad Informática

Es probablemente el tipo de auditoría de TI más conocido y demandado en la actualidad. Su objetivo es evaluar los controles diseñados para proteger la confidencialidad, integridad y disponibilidad de la información (el modelo CIA que estudiamos en el tema 1.1).

➤ Seguridad Física

Evalúa las medidas de protección del entorno físico donde residen los activos tecnológicos.

Aspectos que revisa:

- Control de acceso a instalaciones: ¿Quién puede ingresar al data center? ¿Existen controles biométricos, tarjetas de acceso, guardias de seguridad?
- Condiciones ambientales: ¿El centro de datos cuenta con sistemas de aire acondicionado de precisión? ¿Hay controles de temperatura y humedad?
- Protección contra incendios: ¿Existen detectores de humo? ¿El sistema de extinción de incendios es el adecuado (gases inertes, no agua)?
- Energía eléctrica: ¿Hay sistemas de alimentación ininterrumpida (UPS)? ¿Hay plantas eléctricas de emergencia?
- Vigilancia: ¿Existen cámaras de seguridad? ¿Se monitorean las 24/7?

Ejemplo contextualizado en Nicaragua:

En el data center principal de Claro Nicaragua, una auditoría de seguridad física revisaría si el acceso al servidor que almacena los registros de llamadas de todos los clientes está restringido solo al personal autorizado, si las puertas cuentan con

cerraduras biométricas, si la temperatura se mantiene entre 18 y 22 grados, y si el generador eléctrico tiene suficiente combustible para operar durante un corte prolongado (algo común en Nicaragua).

➤ Seguridad Lógica

Evalúa los controles de acceso a la información a nivel de sistemas, aplicaciones y datos.

Aspectos que revisa:

- Gestión de usuarios y contraseñas: ¿Las contraseñas cumplen requisitos de complejidad? ¿Se cambian periódicamente? ¿Se eliminan las cuentas de empleados que ya no trabajan en la empresa?
- Permisos de acceso: ¿Los usuarios tienen solo los permisos necesarios para realizar su trabajo (principio de mínimo privilegio)?
- Autenticación: ¿Se utiliza autenticación de dos factores (2FA) para accesos críticos?
- Cifrado: ¿La información sensible está cifrada tanto en tránsito (por la red) como en reposo (en discos)?
- Protección perimetral: ¿Los firewalls están correctamente configurados? ¿Los sistemas de detección de intrusos (IDS/IPS) están activos y actualizados?

Ejemplo contextualizado en Nicaragua:

BAC Credomatic Nicaragua procesa millones de transacciones con tarjetas de crédito. Una auditoría de seguridad lógica (que además debe cumplir con el estándar PCI DSS) revisaría si los números de tarjeta (PAN) están cifrados en la base de datos, si los empleados del call center pueden ver los códigos de seguridad (CVV) -que no deberían-, y si los accesos remotos de los proveedores que dan soporte a los sistemas requieren autenticación multifactor.

➤ Seguridad de Recursos Humanos

Evalúa la concienciación y el factor humano en la seguridad.

Aspectos que revisa:

- Programas de formación y concienciación en seguridad para empleados.
- Controles en la contratación y desvinculación de personal.
- Políticas de uso aceptable de los recursos informáticos.

Ejemplo contextualizado en Nicaragua:

En una empresa de zonas francas con alta rotación de personal, como una textilera, una auditoría revisaría si, cuando un supervisor renuncia, se desactiva inmediatamente su acceso a los sistemas de control de producción y nómina, evitando accesos no autorizados posteriores.

Auditoría de Sistemas o Aplicaciones

Se centra en una aplicación de software específica, ya sea desarrollada a la medida o adquirida de un proveedor (ERP, CRM, sistema de nómina, core bancario, etc.). Su objetivo es verificar que la aplicación funcione correctamente, que procese los datos de manera precisa y que tenga los controles adecuados.

➤ Controles de Entrada

Verifican que los datos que ingresan al sistema sean válidos, completos y autorizados.

- Validaciones: ¿El sistema impide registrar una factura con monto negativo?
¿Valida que la cédula de identidad nicaragüense tenga el formato correcto?
- Autorizaciones: ¿Las transacciones que superan cierto monto requieren una autorización adicional?

➤ Controles de Procesamiento

Verifican que el sistema procese los datos correctamente.

- Cálculos: ¿El sistema calcula correctamente el IR (Impuesto sobre la Renta) en una nómina conforme a la tabla vigente de la DGI?
- Integridad referencial: ¿Si se elimina un cliente, se eliminan también sus facturas o se impide la eliminación para mantener la integridad de los datos?

➤ Controles de Salida

- Verifican que los resultados generados por el sistema sean correctos y lleguen solo a quienes deben recibirlos.
- Reportes: ¿Los totales de los reportes coinciden con los registros contables?
- Distribución: ¿Los reportes de nómina solo llegan al gerente de Recursos Humanos?

➤ Pistas de Auditoría (Logs)

Verifican que el sistema registre eventos importantes.

Trazabilidad: ¿Queda registro de quién, cuándo y desde dónde accedió a datos sensibles? ¿Se registran los cambios en información crítica (ej. cambio de salario de un empleado)?

Ejemplo contextualizado en Nicaragua:

Cervecería Nacional utiliza un sistema SAP para gestionar su producción y distribución. Una auditoría de aplicaciones podría enfocarse en el módulo de ventas y revisar:

- Entrada: ¿El sistema impide que un vendedor aplique un descuento superior al 10% sin autorización de su jefe?

- Procesamiento: ¿El sistema calcula correctamente el IVA (15%) para las ventas, diferenciando productos gravados y exentos?
- Salida: ¿El reporte de ventas por ruta que recibe el gerente comercial coincide con los pedidos registrados?
- Logs: ¿Queda registro si alguien intenta modificar el precio de un producto ya facturado?

Auditoría de Infraestructura Tecnológica

Se enfoca en los componentes físicos y de software base que soportan las aplicaciones: servidores, sistemas operativos, almacenamiento, virtualización.

Aspectos que revisa:

- Configuración de servidores: ¿Los servidores están parchados y actualizados? ¿Se siguen buenas prácticas de hardening (endurecimiento) según guías como las del CIS (Center for Internet Security)?
- Inventario: ¿Existe un inventario actualizado de todos los activos tecnológicos?
- Capacidad: ¿Los servidores tienen suficiente capacidad para la demanda actual y futura?
- Monitoreo: ¿Existen herramientas que monitoreen el rendimiento y la disponibilidad de los servidores?

Ejemplo contextualizado en Nicaragua:

En la Alcaldía de Managua, una auditoría de infraestructura revisaría los servidores que alojan el sistema de recaudación de impuestos. Verificaría si los servidores tienen instalados los últimos parches de seguridad de Windows Server, si las políticas de contraseñas del sistema operativo son robustas, y si se realizan monitoreos para detectar cuando la carga del servidor está al límite (para evitar caídas en fechas de pago masivo, como en enero).

Auditoría de Bases de Datos

Se centra en los gestores de bases de datos (Oracle, SQL Server, MySQL, PostgreSQL) y la información que contienen.

Aspectos que revisa:

- Estructura y diseño: ¿La base de datos está normalizada adecuadamente? ¿Existe un diccionario de datos?
- Seguridad: ¿Los accesos a la base de datos están restringidos? ¿Se utilizan cuentas genéricas o cada administrador tiene su propia cuenta?
- Integridad de los datos: ¿Existen llaves foráneas que garanticen la integridad referencial? ¿Hay datos huérfanos?
- Respallos: ¿Se realizan backups de las bases de datos? ¿Se prueban periódicamente las restauraciones?
- Cifrado: ¿Los datos sensibles (ej. números de cédula, información financiera) están cifrados dentro de la base de datos?

Ejemplo contextualizado en Nicaragua:

BANPRO tiene una base de datos con la información de todos sus clientes. Una auditoría de bases de datos revisaría si los DBA (administradores de bases de datos) pueden acceder a los saldos de las cuentas sin dejar rastro, si los backups se almacenan cifrados en cintas fuera del data center principal, y si se han implementado controles para evitar que un programador pueda ejecutar consultas SQL directamente sobre la base de datos de producción.

➤ Auditoría de Redes y Comunicaciones

Evalúa la infraestructura de red que permite la comunicación entre sistemas y usuarios.

Aspectos que revisa:

- Topología y segmentación: ¿La red está segmentada correctamente (DMZ, red interna, red de servidores)? ¿Se separa el tráfico de voz y datos?
- Configuración de dispositivos: ¿Los routers, switches, firewalls están configurados de forma segura? ¿Las contraseñas por defecto han sido cambiadas?
- Monitoreo y disponibilidad: ¿Existe monitoreo de ancho de banda? ¿Hay redundancia de enlaces?
- Redes inalámbricas: ¿Las redes WiFi están protegidas? ¿Se separa la red para empleados de la red para visitantes?
- VPNs: ¿Los accesos remotos a través de VPN están controlados y requieren autenticación fuerte?

Ejemplo contextualizado en Nicaragua:

Tigo Nicaragua tiene una red compleja que soporta servicios de internet, telefonía y televisión. Una auditoría de redes revisaría la segmentación de la red de gestión (donde los administradores configuran los equipos) para asegurar que no sea accesible desde internet, y verificaría que los routers en las oficinas regionales (León, Matagalpa, etc.) tengan configuraciones de seguridad estandarizadas.

➤ Auditoría de Proyectos TI

No audita la tecnología en sí misma, sino la gestión del proyecto que busca crear, implementar o modificar tecnología. Se realiza durante la ejecución del proyecto o al finalizar.

Aspectos que revisa:

- Gestión del alcance: ¿Se han cumplido los requisitos definidos? ¿Ha habido desviaciones?
- Gestión del tiempo: ¿El proyecto avanza según el cronograma? ¿Se identifican y gestionan los retrasos?
- Gestión del costo: ¿El presupuesto se está ejecutando conforme a lo planificado? ¿Hay sobrecostos?
- Gestión de la calidad: ¿Los entregables cumplen con los estándares de calidad definidos?
- Gestión de riesgos: ¿Se han identificado los riesgos del proyecto? ¿Se han implementado planes de mitigación?
- Gestión del cambio: ¿Se ha preparado a los usuarios para el nuevo sistema? ¿Hay un plan de comunicación?

Ejemplo contextualizado en Nicaragua:

El Ministerio de Hacienda y Crédito Público (MHCP) inicia un proyecto para implementar un nuevo sistema de gestión financiera (SAFI) que reemplace al anterior. Contrata a una firma auditora para que, al finalizar cada fase del proyecto, revise si los entregables cumplen lo pactado, si el presupuesto se está gastando adecuadamente y si el cronograma es realista, emitiendo informes que ayuden a la alta dirección a tomar decisiones correctivas a tiempo.

Tipos de Auditoría de TI según el Enfoque o Alcance

Esta clasificación atiende al para qué se audita, es decir, la perspectiva desde la cual se aborda la revisión.

Auditoría de Gobierno de TI

Se enfoca en la alta dirección y en cómo se gestiona estratégicamente la función de TI. No revisa detalles técnicos, sino las políticas, estructuras y procesos que aseguran que TI agregue valor al negocio y gestione sus riesgos adecuadamente. Se basa en marcos como COBIT.

Aspectos que revisa:

- Alineamiento estratégico: ¿Existe un plan estratégico de TI alineado con el plan de negocio?
- Estructura organizativa: ¿La función de TI tiene el nivel jerárquico adecuado? ¿Existe un comité de TI con participación de las áreas de negocio?
- Gestión de inversiones: ¿Cómo se deciden las inversiones en TI? ¿Se evalúa el retorno de la inversión (ROI)?
- Medición del desempeño: ¿Se definen y monitorean indicadores clave de rendimiento (KPI) para TI?
- Gestión de riesgos: ¿Existe un proceso formal para identificar y gestionar los riesgos de TI a nivel corporativo?

Ejemplo contextualizado en Nicaragua:

En la UNHSJM, una auditoría de gobierno de TI revisaría si existe un plan de desarrollo tecnológico para los próximos 5 años, si las decisiones de comprar nuevos laboratorios o licencias se toman en conjunto con las facultades, si la dirección de la universidad recibe informes trimestrales sobre la disponibilidad de la plataforma virtual (Moodle) y si se ha evaluado el riesgo de ciberataques a los sistemas académicos.

Auditoría de Continuidad del Negocio (BCP) y Recuperación ante Desastres (DRP)

Evalúa la capacidad de la organización para recuperar sus sistemas críticos y seguir operando ante un incidente grave (desastre natural, ciberataque, fallo masivo). Es especialmente relevante en países como Nicaragua, con alta actividad sísmica.

Aspectos que revisa:

- Análisis de impacto al negocio (BIA): ¿Se han identificado los procesos críticos y su tolerancia a la interrupción?
- Estrategias de recuperación: ¿Existe un sitio alternativo? ¿Es un sitio caliente (hot site) donde se pueda operar de inmediato, o frío (cold site) que requiere instalación?
- Planes documentados: ¿Existe un plan de continuidad del negocio (BCP) y un plan de recuperación ante desastres (DRP) documentados y aprobados?
- Respallos (backups): ¿Se realizan respaldos de toda la información crítica? ¿Con qué frecuencia? ¿Se almacenan fuera de las instalaciones?
- Pruebas: ¿Se realizan pruebas periódicas de restauración de información y de conmutación al sitio alternativo?

Ejemplo contextualizado en Nicaragua:

LAFISE Bancentro debe garantizar que, aunque ocurra un terremoto que inutilice su edificio principal en Managua, los clientes puedan seguir usando sus tarjetas y la banca en línea. Una auditoría de continuidad revisaría si tienen un centro de datos alternativo en una zona geográficamente distinta (ej. Rivas), si han realizado pruebas de conmutación en los últimos 6 meses, y si los backups se almacenan en una bóveda ignífuga en ese sitio alternativo.

Auditoría de Cumplimiento Normativo en TI

Verifica que la organización cumple con las leyes, regulaciones y estándares aplicables a su sector en materia de tecnología.

Aspectos que revisa:

- Cumplimiento de leyes nacionales: Ley de Protección de Datos Personales (Ley 1042), Código Penal (delitos informáticos).
- Cumplimiento de regulaciones sectoriales: Normas de la SIBOIF para bancos y financieras; NAGUN para el sector público.
- Cumplimiento de estándares internacionales: PCI DSS para quienes procesan pagos con tarjeta; ISO 27001 (si están certificados); SOX (si son filiales de empresas que cotizan en EEUU).

Ejemplo contextualizado en Nicaragua:

Una cooperativa de ahorro y crédito en Matagalpa que ofrece servicios financieros debe cumplir con las disposiciones de la SIBOIF. Una auditoría de cumplimiento en TI revisaría si la cooperativa tiene implementados los controles mínimos de seguridad informática exigidos por el ente regulador, si envía la información requerida en los formatos y plazos establecidos, y si ha realizado las pruebas de vulnerabilidad exigidas.

Auditoría de Calidad de Software (o de Procesos de Desarrollo)

Se enfoca en los procesos mediante los cuales se desarrolla o mantiene el software, así como en la calidad del producto final.

Aspectos que revisa:

- Procesos de desarrollo: ¿Se sigue una metodología definida (ágil, cascada, híbrida)? ¿Se cumplen?

- Pruebas: ¿Existe un proceso de pruebas unitarias, de integración, de aceptación? ¿Se documentan los casos de prueba y los resultados?
- Gestión de requerimientos: ¿Los requerimientos están documentados y aprobados por los usuarios?
- Control de cambios: ¿Los cambios al software pasan por un proceso de autorización, prueba y pase a producción?
- Documentación: ¿Existe documentación técnica y de usuario actualizada?

Ejemplo contextualizado en Nicaragua:

Una empresa de desarrollo de software nicaragüense como Avanzat o Hexa es contratada por el gobierno para desarrollar una aplicación móvil. El gobierno, como parte del contrato, puede solicitar una auditoría de calidad de software para verificar que la empresa está siguiendo buenas prácticas de desarrollo, que el código está documentado y que las pruebas realizadas garantizan que la aplicación funcionará correctamente.

Auditoría Forense Informática (o Digital)

Es la rama más especializada y se activa generalmente después de un incidente de seguridad con posibles implicaciones legales. Su objetivo es investigar, recolectar y preservar evidencias digitales que sean admisibles en un proceso judicial.

Aspectos que revisa:

- Preservación de la evidencia (Cadena de custodia): Se asegura que la evidencia no ha sido alterada desde su recolección.
- Análisis de medios digitales: Se examinan discos duros, memorias USB, teléfonos, servidores, en busca de evidencia (archivos borrados, logs, correos).
- Análisis de redes: Se analizan logs de firewalls, proxies, para determinar el origen de un ataque.

- Reconstrucción de eventos: Se determina qué ocurrió, cuándo, cómo y quién lo hizo.
- Elaboración de informes periciales: Se redacta un informe técnico que pueda ser entendido por un juez y presentado como prueba en un juicio.

Ejemplo contextualizado en Nicaragua:

Un empleado de una empresa distribuidora en Managua, que fue despedido, es sospechoso de haber borrado información clave de los servidores días antes de irse. La empresa presenta una denuncia ante la policía y se solicita una auditoría forense. El auditor forense crea una imagen bit a bit del disco duro del servidor (sin alterarlo), analiza los logs de acceso, identifica que el usuario del empleado ingresó en horario no laboral y borró archivos, y logra recuperar algunos de ellos. Emite un informe pericial que la empresa presenta como evidencia en el juicio laboral y penal.

Tipos de Auditoría de TI según el Momento de Realización

Auditoría Preventiva (o Ex-ante)

Se realiza antes de que ocurran los hechos o durante la implementación de un sistema. Su objetivo es identificar y corregir riesgos y debilidades antes de que se materialicen en problemas.

Ejemplo: Revisar la configuración de seguridad de un nuevo sistema de banca en línea antes de que se ponga en producción, para corregir vulnerabilidades y evitar que sean explotadas por atacantes.

Auditoría Detectiva

Se realiza durante la operación normal. Su objetivo es detectar errores, irregularidades o desviaciones que ya están ocurriendo.

Ejemplo: Revisar periódicamente los logs de accesos a sistemas sensibles para detectar accesos no autorizados o intentos de intrusión.

Auditoría Correctiva (o Ex-post)

Se realiza después de que ha ocurrido un incidente o se ha detectado un problema. Su objetivo es investigar las causas, determinar el alcance del daño y proponer acciones correctivas para que no vuelva a ocurrir.

Ejemplo: Después de que un ataque de ransomware cifró los archivos de una empresa, se realiza una auditoría forense para determinar cómo entró el virus, qué información se perdió y qué controles fallaron, y se recomiendan medidas para prevenir futuros ataques.

Relación entre los Tipos de Auditoría de TI

Es importante entender que estos tipos de auditoría no son mutuamente excluyentes. Una misma auditoría puede combinar varios enfoques. Por ejemplo:

- Una auditoría de seguridad informática (objeto: seguridad) puede ser también una auditoría de cumplimiento (enfoque: verificar cumplimiento de PCI DSS).
- Una auditoría de sistemas (objeto: aplicación) puede formar parte de una auditoría de proyectos (enfoque: evaluar el proyecto de implementación de ese sistema).
- Una auditoría de continuidad (enfoque) necesariamente revisará aspectos de infraestructura (objeto: servidores, backups) y de seguridad (objeto: controles de acceso).

La siguiente tabla resume la relación entre los tipos vistos:

TIPO DE AUDITORÍA DE TI	OBJETO PRINCIPAL DE REVISIÓN	PREGUNTA CLAVE QUE RESPONDE
SEGURIDAD INFORMÁTICA	Controles de protección (físicos, lógicos)	¿Está la información protegida adecuadamente?
SISTEMAS/APLICACIONES	Software específico	¿La aplicación funciona correctamente y tiene controles?
INFRAESTRUCTURA	Servidores, SO, virtualización	¿La base tecnológica es sólida y está bien configurada?
BASES DE DATOS	Gestores de BD y datos	¿Los datos están íntegros, seguros y respaldados?
REDES	Dispositivos de red, comunicaciones	¿La red es segura, confiable y tiene capacidad adecuada?
PROYECTOS TI	Gestión de proyectos tecnológicos	¿El proyecto se está ejecutando correctamente?
GOBIERNO DE TI	Estrategia y dirección de TI	¿TI está alineada con el negocio y agregando valor?
CONTINUIDAD DEL NEGOCIO	Capacidad de recuperación ante desastres	¿Podemos recuperarnos si ocurre un desastre?
CUMPLIMIENTO NORMATIVO	Adherencia a leyes y regulaciones	¿Cumplimos con lo que la ley nos exige?
CALIDAD DE SOFTWARE	Procesos de desarrollo	¿Desarrollamos software de calidad?
FORENSE INFORMÁTICA	Investigación de incidentes	¿Qué ocurrió, quién lo hizo y cómo?

Autoevaluación

Responde las siguientes preguntas para verificar tu comprensión sobre los tipos de auditoría en Tecnologías de Información.

Pregunta 1:

Un auditor de TI revisa la configuración de los firewalls, los sistemas de detección de intrusos y las políticas de contraseñas de una empresa. ¿Qué tipo de auditoría de TI está realizando?

- a) Auditoría de sistemas
- b) Auditoría de seguridad informática (seguridad lógica)
- c) Auditoría de redes
- d) Auditoría de bases de datos

Pregunta 2:

¿Cuál de los siguientes tipos de auditoría se enfoca en verificar si una aplicación de nómina calcula correctamente las deducciones de IR según la tabla de la DGI?

- a) Auditoría de gobierno de TI
- b) Auditoría de continuidad del negocio
- c) Auditoría de sistemas o aplicaciones
- d) Auditoría de infraestructura

Pregunta 3:

Un banco nicaragüense contrata una auditoría para verificar si cumple con las normas de seguridad informática emitidas por la SIBOIF. ¿Qué tipo de auditoría de TI es?

- a) Auditoría forense
- b) Auditoría de proyectos
- c) Auditoría de cumplimiento normativo en TI
- d) Auditoría de calidad de software

Pregunta 4:

Después de un terremoto que dañó el edificio de una empresa, se contrata una auditoría para evaluar si los backups están intactos y si el plan de recuperación ante desastres funciona. ¿Qué tipo de auditoría es?

- a) Auditoría de seguridad física
- b) Auditoría de continuidad del negocio (BCP/DRP)
- c) Auditoría de redes
- d) Auditoría de gobierno de TI

Pregunta 5:

Un auditor forense informático es contratado para investigar un posible fraude interno. ¿Cuál de las siguientes NO es una tarea típica de esta auditoría?

- a) Realizar una imagen bit a bit del disco duro del sospechoso
- b) Evaluar el alineamiento estratégico de TI con el negocio
- c) Mantener la cadena de custodia de la evidencia digital
- d) Recuperar archivos eliminados que puedan ser relevantes para el caso

Pregunta 6 (Caso práctico):

Imagina que una empresa nicaragüense de comercio electrónico (como Yamatú) quiere certificarse en el estándar PCI DSS porque procesa pagos con tarjetas de crédito. ¿Qué tipo de auditoría de TI deberá superar para obtener la certificación? (Selecciona la opción que mejor describa el enfoque principal)

- a) Auditoría de proyectos TI
- b) Auditoría de gobierno de TI
- c) Auditoría de seguridad informática y de cumplimiento normativo
- d) Auditoría de calidad de software

Control Interno y Auditoría de TI

Imaginemos por un momento que una organización es como un barco que navega en aguas cada vez más turbulentas. El capitán (la alta dirección) necesita asegurarse de que el barco no se hunda, que sigue el rumbo correcto y que la tripulación trabaja de manera coordinada. Para ello, cuenta con instrumentos de navegación, procedimientos de seguridad y un manual de operaciones. En el mundo empresarial, ese conjunto de instrumentos, procedimientos y manuales es lo que conocemos como Control Interno.

El control interno es la columna vertebral de cualquier organización, y en el ámbito de las Tecnologías de Información, adquiere una relevancia aún mayor. Los sistemas de información procesan transacciones por millones, almacenan datos sensibles y soportan procesos críticos de negocio. Si los controles internos en TI son débiles o inexistentes, la organización navega sin brújula, expuesta a fraudes, errores, incumplimientos normativos y desastres operativos.

En este tema, exploraremos en profundidad qué es el control interno, cuáles son sus componentes, cómo se aplica específicamente al entorno de TI y, lo más importante, cuál es la relación entre el control interno y la auditoría. Porque el auditor de TI no es un enemigo de los controles, sino su principal evaluador y aliado para mejorarlos.

Concepto de Control Interno

Definición

El control interno es un proceso integral, dinámico y continuo, diseñado y ejecutado por la dirección, la gerencia y el personal de una entidad, para proporcionar un grado de seguridad razonable en cuanto a la consecución de los objetivos de la organización en las siguientes categorías:

- Eficacia y eficiencia de las operaciones: Que la organización use bien sus recursos y logre sus metas.

- Confiabilidad de la información financiera y no financiera: Que los informes que se generan (internos y externos) sean precisos y completos.
- Cumplimiento de las leyes y regulaciones aplicables: Que la organización no viole normas legales o internas.

Elementos clave de esta definición:

- Es un proceso: No es un evento aislado ni un manual que se archiva. Es una serie de acciones que impregnan todas las actividades de la organización.
- Lo ejecutan personas: No son solo políticas y procedimientos escritos; son las personas en todos los niveles quienes aplican el control interno.
- Proporciona seguridad razonable, no absoluta: Por más robusto que sea un sistema de control interno, siempre existirá la posibilidad de error humano, colusión o decisiones gerenciales que lo sobrepasen. El control interno reduce riesgos, no los elimina por completo.
- Orientado a objetivos: El control interno no existe por sí mismo; existe para ayudar a la organización a alcanzar sus metas.

En BANPRO, el control interno incluye, entre muchas otras cosas:

- Operaciones: Políticas que exigen que los cajeros automaticen sus cuadros al final del día y que un supervisor los revise (eficiencia y eficacia).
- Información: Que el sistema bancario registre automáticamente cada transacción y que los saldos contables coincidan con los saldos operativos (confiabilidad).
- Cumplimiento: Que se verifique la identidad de los clientes que abren cuentas conforme a las normas de la SIBOIF para prevenir lavado de dinero (cumplimiento).

Importancia del Control Interno en las Organizaciones

Un sistema de control interno sólido es vital por múltiples razones:

- Previene fraudes y errores: Al establecer segregación de funciones, autorizaciones y verificaciones, se dificulta que una persona pueda cometer y ocultar un fraude.
- Protege los activos: Tanto físicos (equipos, instalaciones) como intangibles (información, propiedad intelectual).
- Asegura la calidad de la información: La toma de decisiones se basa en información confiable. Si los controles fallan, las decisiones pueden ser erróneas.
- Facilita el cumplimiento normativo: Ayuda a la organización a demostrar ante reguladores (SIBOIF, DGI, Contraloría) que cumple con las leyes.
- Mejora la eficiencia operativa: Al estandarizar procesos y eliminar duplicidades, se optimiza el uso de los recursos.
- Genera confianza: En inversionistas, socios comerciales, clientes y el público en general.

Principales Modelos de Control Interno

Existen varios marcos de referencia que ayudan a las organizaciones a diseñar, implementar y evaluar sus sistemas de control interno. Los más reconocidos a nivel mundial son:

Modelo COSO (Committee of Sponsoring Organizations of the Treadway Commission)

Es el marco de control interno más utilizado en el mundo. Fue desarrollado en Estados Unidos en 1992 y actualizado en 2013 (COSO III). Define el control interno a través de cinco componentes integrados:

```

flowchart TD
    subgraph A[Componentes de COSO]
        direction TB
        C1[1. Ambiente de Control]
        C2[2. Evaluación de Riesgos]
        C3[3. Actividades de Control]
        C4[4. Información y Comunicación]
        C5[5. Supervisión y Monitoreo]
    end

    C1 --> C2 --> C3 --> C4 --> C5
    C5 -.-> C1

```

1. Ambiente de Control:

Es la base de todos los demás componentes. Define el "tono" de la organización, la cultura de control. Incluye:

- Integridad y valores éticos.
- Filosofía de la dirección y estilo de gestión.
- Estructura organizativa y asignación de autoridad y responsabilidad.
- Políticas de recursos humanos.

2. Evaluación de Riesgos:

La organización debe identificar y analizar los riesgos que pueden impedir el logro de sus objetivos. Esto implica:

- Identificación de riesgos internos y externos.
- Análisis de la probabilidad e impacto de los riesgos.
- Determinación de cómo gestionar esos riesgos (aceptarlos, mitigarlos, transferirlos, evitarlos).

3. Actividades de Control:

Son las políticas y procedimientos que aseguran que se implementen las directrices de la dirección. Incluyen:

- Aprobaciones y autorizaciones.
- Segregación de funciones.
- Verificaciones y conciliaciones.

- Controles físicos sobre activos.
- Indicadores de desempeño.

4. Información y Comunicación:

La organización debe generar y utilizar información relevante y de calidad, y comunicarla adecuadamente a quienes la necesitan. Incluye:

- Sistemas de información (manuales y automatizados).
- Canales de comunicación interna (hacia empleados) y externa (hacia stakeholders).

5. Supervisión y Monitoreo:

El sistema de control interno debe ser monitoreado continuamente para evaluar su desempeño y detectar deficiencias. Incluye:

- Actividades de monitoreo continuo (ej. revisiones periódicas de la gerencia).
- Evaluaciones separadas (como las auditorías internas y externas).

Ejemplo aplicando COSO:

Imaginemos el MINSA (Ministerio de Salud) y su sistema de gestión de inventarios de medicamentos:

- Ambiente de Control: Existe un código de ética para los funcionarios que manejan compras de medicamentos. La estructura organizativa define claramente quién puede autorizar una compra.
- Evaluación de Riesgos: Se identifica que un riesgo importante es el vencimiento de medicamentos antes de ser distribuidos. Se evalúa la probabilidad e impacto.
- Actividades de Control: Se establece un procedimiento de "primeras entradas, primeras salidas" (PEPS) para los inventarios. Se requiere una autorización especial para dar de baja medicamentos vencidos.

- Información y Comunicación: El sistema informático de inventarios genera reportes semanales de medicamentos próximos a vencer y los envía automáticamente a los responsables de los centros de salud.
- Supervisión y Monitoreo: La auditoría interna del MINSA revisa periódicamente los reportes de vencimientos y realiza conteos físicos sorpresa en las bodegas.

Modelo COSO ERM (Enterprise Risk Management)

Es una ampliación del COSO original, enfocada específicamente en la gestión integral de riesgos a nivel empresarial. Añade una perspectiva más estratégica y considera el riesgo no solo como algo negativo, sino también como oportunidad.

Modelo CoCo (Criteria of Control Board)

Desarrollado por el Instituto Canadiense de Contadores Certificados (CICA). Es similar a COSO pero con un enfoque más orientado a la cultura organizacional y al aprendizaje.

El Control Interno en el Entorno de TI

La tecnología ha transformado la forma en que se aplican los controles internos. Muchos controles que antes eran manuales ahora están automatizados, y han surgido nuevos riesgos que requieren nuevos tipos de controles. Aquí es donde entra la **Auditoría de TI**. Los controles en el entorno de TI se clasifican tradicionalmente en dos grandes categorías:

Controles Generales de TI (ITGC - Information Technology General Controls)

Son aquellos que aplican a todas las áreas de TI de la organización, independientemente de la aplicación específica. Son la base sobre la que se construyen los controles de las aplicaciones. Si los controles generales son débiles, los controles de las aplicaciones pueden ser fácilmente vulnerados.

Las principales áreas de los Controles Generales de TI son:

ÁREA DE CONTROL	DESCRIPCIÓN	EJEMPLOS DE CONTROLES
GESTIÓN DE LA SEGURIDAD LÓGICA	Controles que garantizan que solo los usuarios autorizados accedan a los sistemas y datos.	- Políticas de contraseñas robustas. - Autenticación multifactor. - Revisión periódica de usuarios y permisos. - Desactivación inmediata de cuentas de empleados que se retiran.
GESTIÓN DE CAMBIOS	Controles que aseguran que los cambios en sistemas, aplicaciones y configuraciones sean autorizados, probados e implementados de manera controlada.	- Procedimientos formales de solicitud de cambio. - Entornos de desarrollo, prueba y producción separados. - Pruebas de aceptación por usuarios antes de pasar a producción. - Registro de todos los cambios implementados.
GESTIÓN DE OPERACIONES	Controles que garantizan que las operaciones diarias de TI se realicen de manera eficiente, segura y confiable.	- Monitoreo de la capacidad de servidores. - Gestión de incidentes y problemas. - Procedimientos de inicio y parada de sistemas. - Control de horarios de procesamiento por lotes (batch).
CONTINUIDAD DEL NEGOCIO Y RECUPERACIÓN ANTE DESASTRES	Controles que aseguran la disponibilidad de los sistemas críticos ante interrupciones.	- Respaldos (backups) periódicos y probados. - Plan de continuidad del negocio (BCP) documentado. - Sitio alternativo de procesamiento. - Pruebas periódicas de recuperación.
GESTIÓN DE ADQUISICIONES, DESARROLLO Y MANTENIMIENTO	Controles sobre cómo se adquieren o desarrollan nuevos sistemas.	- Metodologías de desarrollo definidas. - Evaluación de proveedores. - Pruebas de seguridad en el ciclo de vida del desarrollo.
SEGURIDAD FÍSICA	Controles que protegen las instalaciones donde residen los activos tecnológicos.	- Control de acceso biométrico al data center.

- CCTV (circuito cerrado de televisión).
- Sistemas de detección y extinción de incendios.
- Control de temperatura y humedad.

Ejemplo Controles Generales de TI:

En TELCOR, el ente regulador de telecomunicaciones:

- Seguridad Lógica: Solo los administradores autorizados pueden acceder a los servidores que gestionan los dominios .ni. Las contraseñas se cambian cada 60 días.
- Gestión de Cambios: Cualquier modificación en el sistema de registro de dominios debe pasar por un comité de cambios que aprueba la solicitud, y debe probarse en un ambiente de pruebas antes de implementarse en producción.
- Operaciones: Se monitorea las 24/7 la disponibilidad del sitio web que permite consultar disponibilidad de dominios.
- Continuidad: Se realizan backups diarios de la base de datos de dominios y se almacenan en una ubicación externa.
- Seguridad Física: El data center de TELCOR tiene control de acceso con tarjeta y biometría, y cuenta con un sistema de extinción de incendios por gas FM200.

Controles de Aplicación

Son aquellos que están integrados dentro de las aplicaciones de software para garantizar la integridad, precisión y validez del procesamiento de datos. Se aplican a transacciones y datos específicos.

Como vimos brevemente en el tema 1.3, se clasifican en:

- **Controles de Entrada:** Aseguran que los datos que ingresan a la aplicación sean válidos, completos y autorizados. Ejemplo: Un sistema de facturación de La Colonia no permite registrar una venta con un código de producto inexistente. El sistema valida que el número de cédula del cliente tenga 14 dígitos (formato Nicaragua).
- **Controles de Procesamiento:** Aseguran que los datos sean procesados correctamente por la aplicación. Ejemplo: El sistema de nómina de Cervecería Nacional calcula automáticamente las horas extras conforme a lo establecido en el Código del Trabajo de Nicaragua (primeras dos horas al 100%, siguientes al 200%, etc.).
- **Controles de Salida:** Aseguran que los resultados del procesamiento sean correctos y que solo lleguen a destinatarios autorizados. Ejemplo: El sistema de la DGI que genera los reportes de declaración de impuestos de los contribuyentes tiene un control que verifica que los totales de la declaración electrónica coincidan con los cálculos internos del sistema antes de aceptarla.

Relación entre el Control Interno y la Auditoría de TI

La relación es de evaluación y mejora continua. El auditor de TI es, ante todo, un evaluador del sistema de control interno.

El auditor como evaluador del control interno

El auditor de TI examina los controles internos (tanto generales como de aplicación) para determinar:

- **Si están diseñados adecuadamente:** Es decir, si los controles existentes, en teoría, serían capaces de prevenir o detectar errores o irregularidades. Un control mal diseñado no servirá de nada.
- **Si operan de manera efectiva:** Es decir, si los controles realmente se aplican en la práctica y funcionan como se espera. Un control bien diseñado pero que no se aplica (ej. una política de contraseñas que nadie cumple) es igualmente inútil.

Tipos de pruebas que realiza el auditor sobre los controles

- Pruebas de cumplimiento (o de controles): El auditor verifica que el control existe y funciona. Por ejemplo, revisa una muestra de solicitudes de acceso a sistemas para verificar que todas fueron autorizadas por el jefe correspondiente.
- Pruebas sustantivas: Si el auditor encuentra que los controles son débiles, o como complemento, realiza pruebas directamente sobre los datos para detectar errores o irregularidades. Por ejemplo, si el control de autorización de accesos es débil, el auditor podría analizar los logs de acceso para ver si hay accesos no autorizados.

El Ciclo de Mejora Continua

La auditoría de TI alimenta un ciclo de mejora continua del control interno:

- Diseño/Implementación: La organización diseña e implementa controles.
- Auditoría: El auditor de TI evalúa los controles.
- Hallazgos y Recomendaciones: El auditor identifica debilidades (debilidades de control) y recomienda mejoras.
- Acción Correctiva: La gerencia implementa las recomendaciones del auditor.
- Seguimiento: El auditor verifica, en una auditoría posterior, que las acciones correctivas se implementaron y fueron efectivas.

flowchart LR

A[Diseño e Implementación
de Controles] --> B[Auditoría de TI
(Evaluación)]

B --> C{¿Controles
efectivos?}

C -->|Sí| D[Confianza en los controles]

C -->|No| E[Identificación de
Debilidades y Riesgos]

E --> F[Recomendaciones
de Mejora]

F --> G[Implementación de
Acciones Correctivas]

G --> B

Ejemplo del ciclo de mejora:

- Escenario: La auditoría interna de la Alcaldía de Managua revisa el control de acceso al sistema de recaudación de impuestos municipales.
- Diseño: La política establece que cada empleado debe tener su propio usuario y contraseña, y que los permisos deben ser asignados por su jefe mediante un formulario.
- Auditoría: El auditor revisa una muestra de 50 usuarios y encuentra que 10 de ellos corresponden a exempleados que ya no trabajan en la alcaldía (hace 3, 6 y hasta 8 meses). El control no se está aplicando.
- Hallazgo: El auditor emite un hallazgo: "Usuarios de exempleados activos en el sistema de recaudación, lo que representa un riesgo de acceso no autorizado y posible manipulación de datos".
- Recomendación: El auditor recomienda implementar un procedimiento automático que desactive las cuentas de usuarios cuando sean dados de baja en el sistema de recursos humanos, y realizar revisiones trimestrales de usuarios.
- Acción Correctiva: La dirección de informática implementa un script que sincroniza el sistema de RRHH con el sistema de recaudación y desactiva automáticamente las cuentas.
- Seguimiento: En la siguiente auditoría, 6 meses después, el auditor verifica que ya no existen cuentas de exempleados activas.

El informe de auditoría y las debilidades de control

Cuando un auditor de TI identifica una debilidad en el control interno, la clasifica según su severidad:

- Debilidad material (o deficiencia significativa): Es una debilidad, o combinación de debilidades, que puede resultar en una incorrección material en la información financiera o en un incumplimiento grave de normativas. Requiere atención inmediata de la alta dirección.

- Deficiencia significativa: Es una debilidad menos severa que una debilidad material, pero lo suficientemente importante como para merecer la atención de los responsables del gobierno de la entidad.
- Deficiencia de control: Es cualquier debilidad en el diseño u operación de un control que no alcanza el nivel de significativa.

Responsabilidades en el Control Interno de TI

Es importante entender quién hace qué en relación con el control interno:

- La Alta Dirección (Junta Directiva, Gerencia General): Es la principal responsable de establecer, implementar y supervisar el sistema de control interno. Debe definir el "tono desde arriba" y asegurar los recursos necesarios.
- La Gerencia de TI: Es responsable de diseñar e implementar los controles específicos en su área, alineados con las directrices de la alta dirección.
- Todos los empleados: Son responsables de aplicar los controles en su trabajo diario y de reportar cualquier debilidad o irregularidad que detecten.
- Auditoría Interna: Es responsable de evaluar la efectividad del sistema de control interno y reportar sus hallazgos a la alta dirección y al comité de auditoría.
- Auditoría Externa: Evalúa el control interno en la medida necesaria para poder emitir su opinión sobre los estados financieros o sobre el cumplimiento de algún estándar específico.

El control interno y la auditoría de TI son dos caras de la misma moneda. El primero es el sistema de defensa de la organización; la segunda es quien evalúa qué tan sólidas son esas defensas. Un auditor de TI no puede realizar su trabajo sin comprender a fondo los principios del control interno, y una organización no puede tener un sistema de control interno robusto sin someterlo periódicamente a la evaluación independiente de auditores.

En el entorno digital actual, donde los riesgos cibernéticos crecen exponencialmente y la dependencia tecnológica es absoluta, el binomio control interno-auditoría de TI se convierte en un factor crítico para la supervivencia y el éxito de cualquier organización, sea pública o privada, grande o pequeña.

Autoevaluación

Responde las siguientes preguntas para verificar tu comprensión sobre el control interno y su relación con la auditoría de TI.

Pregunta 1:

¿Cuál es el principal marco de referencia utilizado a nivel mundial para el diseño, implementación y evaluación de sistemas de control interno?

- a) ISO 27001
- b) COBIT
- c) COSO
- d) ITIL

Pregunta 2:

Según la definición de control interno, ¿qué tipo de seguridad proporciona?

- a) Seguridad absoluta
- b) Seguridad razonable
- c) Seguridad total
- d) Seguridad limitada solo a lo financiero

Pregunta 3:

Los Controles Generales de TI (ITGC) incluyen todas las siguientes áreas, EXCEPTO:

- a) Gestión de cambios
- b) Seguridad lógica

- c) Controles de validación de entrada en una factura
- d) Continuidad del negocio

Pregunta 4:

Si un auditor de TI verifica que todas las solicitudes de cambio a un sistema hayan sido aprobadas por el comité de cambios antes de implementarse, ¿qué tipo de prueba está realizando?

- a) Prueba sustantiva
- b) Prueba de cumplimiento (o de controles)
- c) Prueba de recorrido (walkthrough)
- d) Prueba de integridad de datos

Pregunta 5:

En el modelo COSO, ¿cuál de los siguientes NO es uno de sus cinco componentes?

- a) Ambiente de control
- b) Evaluación de riesgos
- c) Gestión de proveedores
- d) Actividades de control

Pregunta 6 (Caso práctico):

Un auditor de TI está revisando el sistema de nómina de una empresa. Descubre que un mismo empleado (el administrador del sistema) puede crear usuarios, asignar permisos, procesar la nómina y autorizar los pagos. ¿Qué principio fundamental de control interno se está violando?

- a) Autorización
- b) Segregación de funciones
- c) Conciliación
- d) Monitoreo

Pregunta 7 (Caso práctico):

En una cooperativa de ahorro y crédito en Estelí, el auditor de TI encuentra que el data center (un pequeño cuarto con los servidores) no tiene puerta con cerradura especial, cualquier empleado puede entrar, no hay control de temperatura y los backups se guardan en un estante dentro del mismo cuarto. ¿Qué tipo de control general de TI es deficiente principalmente?

- a) Gestión de cambios
- b) Seguridad lógica
- c) Seguridad física
- d) Gestión de operaciones

Características y Funciones del Auditor de TI

Hemos recorrido un largo camino en esta unidad: conocemos los conceptos fundamentales, los antecedentes históricos, los diferentes tipos de auditoría de TI y la importancia del control interno. Ahora nos enfrentamos a una pregunta crucial: ¿quién es la persona encargada de llevar a cabo todo esto?

El auditor de Tecnologías de Información no es un técnico más en la organización. Es un profesional con una formación híbrida única, que combina conocimientos tecnológicos profundos con habilidades de análisis, comunicación y juicio crítico propias de la auditoría. Es, al mismo tiempo, un evaluador, un asesor y un guardián de la confianza.

En este tema, exploraremos en detalle el perfil del auditor de TI: sus características personales y profesionales, sus funciones específicas dentro de la organización, los principios éticos que rigen su actuación y las certificaciones que acreditan su competencia. Comprenderemos por qué no cualquier persona con conocimientos de computación puede ser un buen auditor de TI, y qué se necesita para destacar en esta apasionante profesión.

¿Quién es el Auditor de TI?

El auditor de Tecnologías de Información es un profesional independiente y objetivo que posee los conocimientos, habilidades y experiencia necesarios para examinar, evaluar y emitir una opinión sobre los sistemas de información, la infraestructura tecnológica, los procesos de TI y los controles internos relacionados, con el fin de determinar si estos son adecuados, eficaces y están alineados con los objetivos del negocio, así como si cumplen con las leyes, regulaciones y estándares aplicables.

No es un simple "revisor de computadoras". Es un profesional que entiende el negocio, sus riesgos y cómo la tecnología impacta en la consecución de sus metas.

Su valor radica en su capacidad para traducir la complejidad técnica en información comprensible y útil para la toma de decisiones por parte de la alta dirección.

Características del Auditor de TI

Para desempeñar su labor con éxito, un auditor de TI debe reunir una serie de características que podemos agrupar en tres categorías: personales, técnicas y éticas.

Características Personales

Característica	Descripción	Importancia en el Contexto Nicaragüense
Objetividad e Independencia	Capacidad para mantener una actitud imparcial, libre de sesgos, conflictos de interés o influencias que puedan afectar su juicio profesional.	En un país donde las relaciones personales y profesionales pueden estar muy entrelazadas, el auditor debe ser especialmente cuidadoso de mantener su independencia, sobre todo en auditorías internas o en empresas de tamaño mediano donde "todos se conocen".
Pensamiento Crítico y Analítico	Habilidad para descomponer problemas complejos en partes manejables, identificar patrones, cuestionar suposiciones y llegar a conclusiones lógicas basadas en evidencia.	Esencial para evaluar si un control mal diseñado es realmente la causa de un problema, o si hay factores subyacentes más profundos (cultura organizacional, falta de recursos) que explican las debilidades encontradas.
Curiosidad Profesional (Escepticismo Profesional)	Actitud que implica una mente inquisitiva y una evaluación crítica de la evidencia, sin asumir automáticamente que la gerencia es honesta o que los controles funcionan.	Nicaragua ha tenido casos de fraudes internos en diversas organizaciones. Un auditor con escepticismo profesional no se conforma con la primera explicación; profundiza, pide más evidencias y no da nada por sentado.

Característica	Descripción	Importancia en el Contexto Nicaragüense
Comunicación Efectiva	Capacidad para expresar ideas de forma clara, tanto oralmente como por escrito, adaptando el lenguaje a la audiencia (técnica o gerencial).	Debe poder explicarle a un gerente de negocio, que no sabe de tecnología, por qué una vulnerabilidad en un servidor puede afectar las ventas. También debe redactar informes de auditoría claros, precisos y convincentes.
Integridad y Ética	Firmeza en sus principios morales, honestidad y responsabilidad en el ejercicio de su profesión.	En un entorno donde a veces se normalizan ciertas prácticas "informales", el auditor debe ser un ejemplo de rectitud y apego a las normas.
Tacto y Diplomacia	Habilidad para tratar con personas de diferentes niveles jerárquicos, comunicar hallazgos negativos sin generar hostilidad y construir relaciones de confianza.	El auditor no es un "policía" que llega a castigar. Es un evaluador que debe presentar sus hallazgos de manera constructiva, ayudando a los auditados a entender los riesgos y a aceptar las recomendaciones.
Adaptabilidad y Aprendizaje Continuo	Capacidad para adaptarse a entornos cambiantes y disposición permanente para aprender nuevas tecnologías, metodologías y regulaciones.	La tecnología avanza rápidamente; lo que era relevante hace un año puede estar obsoleto. Un auditor de TI en Nicaragua debe mantenerse actualizado leyendo, estudiando y formándose continuamente.

Características Técnicas (Conocimientos)

El auditor de TI debe poseer un sólido conocimiento en diversas áreas tecnológicas y de auditoría:

Conocimientos de Auditoría:

- Normas internacionales de auditoría (NIAs, ISAs).
- Metodologías y técnicas de auditoría (muestreo, entrevistas, revisión documental, análisis de datos).
- Marcos de control interno (COSO, COSO ERM).

Gestión de riesgos.

Conocimientos de Tecnologías de Información:

- Sistemas Operativos: Windows Server, Linux/Unix, macOS.
- Bases de Datos: Oracle, SQL Server, MySQL, PostgreSQL.
- Redes y Comunicaciones: TCP/IP, firewalls, routers, switches, VPNs, protocolos de red.
- Seguridad Informática: Criptografía, autenticación, control de accesos, seguridad perimetral, análisis de vulnerabilidades, pruebas de penetración (pentesting).
- Desarrollo de Software: Ciclo de vida del desarrollo, metodologías ágiles y tradicionales, lenguajes de programación (para entender el código, no necesariamente para desarrollarlo).
- Infraestructura: Servidores, almacenamiento, virtualización (VMware, Hyper-V), cloud computing (AWS, Azure, Google Cloud).
- Gobierno de TI: Marcos como COBIT, ITIL, ISO 38500.

Conocimientos del Negocio y del Entorno Legal:

- Comprensión del modelo de negocio de la organización que audita.
- Conocimiento de las leyes y regulaciones aplicables en Nicaragua (Ley 1042 de Protección de Datos, Código Penal, NAGUN, normas SIBOIF, etc.).
- Conocimiento de estándares internacionales relevantes (PCI DSS, ISO 27001, SOX).

Ejemplo de la necesidad de conocimientos técnicos en Nicaragua:

Un auditor de TI que trabaja para la Superintendencia de Bancos (SIBOIF) , supervisando a bancos como LAFISE o BAC, necesita conocimientos técnicos profundos para entender si los controles de seguridad en el core bancario son adecuados, si las configuraciones de red aíslan correctamente los sistemas de pago, y si los planes de continuidad son técnicamente viables.

Características Éticas (Código de Ética)

Las principales asociaciones profesionales de auditores, como ISACA (Information Systems Audit and Control Association) y IIA (Institute of Internal Auditors), han establecido códigos de ética que todo auditor de TI debe cumplir. Los principios fundamentales son:

- Integridad: Actuar con honestidad, diligencia y responsabilidad en el desempeño de sus funciones.
- Objetividad: No permitir que sesgos, conflictos de interés o influencias indebidas prevalezcan sobre su juicio profesional.
- Confidencialidad: Proteger la información obtenida en el curso de su trabajo, no revelarla sin la debida autorización, a menos que exista una obligación legal o profesional de hacerlo.
- Competencia Profesional: Mantener y mejorar continuamente sus conocimientos y habilidades, y actuar dentro de los límites de su competencia.

- Debido Cuidado Profesional: Cumplir con las normas técnicas aplicables y ejercer su trabajo con la diligencia y el esmero esperados de un profesional razonablemente prudente y competente.

Funciones del Auditor de TI

Las funciones de un auditor de TI pueden variar según el tipo de organización, su tamaño, el sector y si se trata de auditoría interna o externa. Sin embargo, podemos identificar un conjunto de funciones generales que son comunes a la mayoría de los puestos.

Funciones Principales

FUNCIÓN	DESCRIPCIÓN	ACTIVIDADES ESPECÍFICAS
PLANIFICACIÓN DE AUDITORÍAS	Definir el alcance, los objetivos, la metodología y los recursos necesarios para cada auditoría.	- Identificar los procesos, sistemas o áreas a auditar. - Realizar una evaluación preliminar de riesgos. - Definir los criterios de auditoría (normas, estándares contra los que se auditará). - Elaborar el programa de trabajo detallado.
EVALUACIÓN DE CONTROLES INTERNOS	Examinar y probar los controles generales de TI y los controles de aplicación.	- Revisar políticas y procedimientos de TI. - Evaluar la segregación de funciones. - Probar la efectividad de los controles de acceso lógico. - Verificar la gestión de cambios en sistemas. - Evaluar los controles de entrada, procesamiento y salida en aplicaciones.
EVALUACIÓN DE RIESGOS	Identificar y analizar los riesgos tecnológicos que pueden afectar a la organización.	- Participar en la identificación de riesgos de TI a nivel corporativo. - Evaluar la exposición a ciberataques, fraudes internos, desastres naturales, etc. - Determinar la probabilidad e impacto de los riesgos identificados.
PRUEBAS DE AUDITORÍA	Ejecutar procedimientos para	- Realizar entrevistas con personal clave. - Revisar documentación (políticas, actas, reportes).

	obtener evidencia suficiente y adecuada.	- Analizar configuraciones de sistemas, logs y bases de datos. - Utilizar herramientas automatizadas de auditoría (CAATs) para analizar grandes volúmenes de datos. - Realizar pruebas de vulnerabilidad y, en algunos casos, pruebas de penetración (con autorización).
DOCUMENTACIÓN DE HALLAZGOS	Registrar de manera clara y organizada todo el trabajo realizado y la evidencia obtenida.	- Elaborar papeles de trabajo que respalden las conclusiones. - Describir los hallazgos (condición, criterio, causa, efecto). - Vincular cada hallazgo con la evidencia que lo soporta.
COMUNICACIÓN DE RESULTADOS	Elaborar informes de auditoría claros, precisos y oportunos, y presentarlos a las partes interesadas.	- Redactar el informe de auditoría con introducción, alcance, objetivos, hallazgos, conclusiones y recomendaciones. - Presentar los resultados a la gerencia y al comité de auditoría. - Discutir los hallazgos con los auditados para asegurar la comprensión y aceptación.
SEGUIMIENTO	Verificar que las recomendaciones de auditoría sean implementadas por la gerencia.	- Solicitar a la gerencia un plan de acción con plazos y responsables. - Realizar revisiones periódicas para verificar el avance en la implementación. - En auditorías posteriores, confirmar que las debilidades han sido corregidas.
ASESORÍA Y CONSULTORÍA	Actuar como asesor confiable en materia de control interno, riesgos y gobierno de TI.	- Participar en comités de proyectos para asesorar sobre controles desde el inicio. - Opinar sobre nuevas tecnologías o cambios significativos. - Contribuir a la definición de políticas y procedimientos de TI.
INVESTIGACIÓN DE INCIDENTES	Participar, en coordinación con otras áreas, en la	- Apoyar en la recolección y preservación de evidencias digitales. - Analizar logs y registros para determinar el origen y

investigación de	alcance de un incidente.
incidentes de seguridad	- Elaborar informes técnicos para sustentar acciones
o fraudes.	legales

Ejemplo del ciclo de funciones:

Imaginemos a María, auditora de TI en la Contraloría General de la República.

- Planificación: María recibe el encargo de auditar el sistema SAFI (Sistema de Administración Financiera Integrado) del Ministerio de Educación. Define el alcance (módulo de ejecución presupuestaria) y los objetivos (verificar que los pagos a proveedores tengan las autorizaciones requeridas).
- Evaluación de Controles: Revisa las políticas del SAFI. Encuentra que, en teoría, los pagos superiores a C\$100,000 requieren doble firma electrónica.
- Pruebas: Solicita un listado de todos los pagos > C\$100,000 del último trimestre. Mediante análisis de datos, verifica cuáles tienen realmente la doble firma registrada en el sistema.
- Hallazgo: Encuentra 15 pagos por un total de C\$2.5 millones que solo tienen una firma, violando la política.
- Documentación: Documenta el hallazgo: condición (pagos con una sola firma), criterio (política que exige doble firma), causa (posiblemente, el sistema no fuerza la doble firma, o los usuarios encuentran la forma de evadirla), efecto (riesgo de pagos no autorizados o fraudulentos).
- Comunicación: Redacta un informe y lo presenta al ministro y al titular de la Contraloría. Recomendación: corregir la configuración del SAFI para que técnicamente sea imposible realizar un pago > C\$100,000 sin dos firmas.
- Seguimiento: Seis meses después, María vuelve a verificar y confirma que el sistema fue corregido y ya no se permiten pagos con una sola firma.

Funciones Específicas según el Tipo de Auditoría

Tipo de Auditoría	Funciones Específicas del Auditor de TI
Auditoría de Seguridad	Realizar escaneos de vulnerabilidades, revisar configuraciones de firewalls e IDS, evaluar la seguridad física del data center, verificar la existencia de un programa de concienciación en seguridad.
Auditoría de Sistemas	Revisar la lógica de los programas (mediante revisión de código o pruebas de caja negra), verificar la integridad de los datos en las bases de datos, evaluar los controles de acceso a la aplicación.
Auditoría de Proyectos	Revisar la documentación del proyecto, evaluar si se sigue la metodología establecida, verificar la gestión de riesgos del proyecto, validar que las pruebas hayan sido suficientes antes del pase a producción.
Auditoría de Cumplimiento	Verificar, mediante pruebas específicas, el cumplimiento de la Ley 1042 (protección de datos), de las normas de la SIBOIF, del estándar PCI DSS, etc.
Auditoría Forense	Preservar la evidencia digital (cadena de custodia), realizar imágenes forenses de discos, analizar logs y archivos en busca de evidencia, elaborar informes periciales.
Auditoría de Continuidad	Revisar el plan de continuidad, probar la restauración de backups, evaluar la idoneidad del sitio alternativo, presenciar simulacros de desastre.

El Auditor de TI y la Estructura Organizacional

La ubicación del auditor de TI dentro de la organización es crucial para garantizar su independencia y objetividad.

Auditoría Interna de TI

En este caso, el auditor de TI es empleado de la organización y forma parte del departamento de Auditoría Interna (o, en organizaciones más grandes, de una unidad especializada de Auditoría de TI dentro de Auditoría Interna).

- Dependencia jerárquica: Debe depender funcionalmente del Comité de Auditoría de la Junta Directiva, y administrativamente del máximo ejecutivo (Gerente General). Esta doble dependencia protege su independencia.
- Ventajas: Conocimiento profundo de la organización, disponibilidad continua, enfoque preventivo y de mejora continua.
- Desventajas: Posible pérdida de objetividad por la cercanía, limitaciones de recursos o presión interna.

Ejemplo:

BANPRO tiene un departamento de Auditoría Interna que incluye varios auditores de TI. Ellos reportan al Comité de Auditoría de la Junta Directiva, no al Gerente de TI ni al Gerente General. Esto les permite auditar la gestión del Gerente de TI sin temor a represalias.

Auditoría Externa de TI

El auditor de TI trabaja para una firma de auditoría o consultoría independiente (como las "Big Four": Deloitte, PwC, EY, KPMG, o firmas locales como Grant Thornton Nicaragua, BDO Nicaragua, o Auren).

- Dependencia jerárquica: Depende de su firma, no de la organización auditada.
- Ventajas: Máxima independencia, exposición a diferentes industrias y realidades, actualización constante, recursos especializados.
- Desventajas: Conocimiento menos profundo de la organización, disponibilidad limitada al período de la auditoría.

Ejemplo:

La Alcaldía de Managua contrata a KPMG Nicaragua para que realice una auditoría externa de sus estados financieros. KPMG asigna un equipo que incluye auditores de TI, quienes pasarán varias semanas en la alcaldía revisando los sistemas, pero no son empleados de la alcaldía.

Certificaciones Profesionales para el Auditor de TI

En un mundo cada vez más competitivo, las certificaciones profesionales son una forma de demostrar formalmente la competencia y el conocimiento en el área. Son especialmente valoradas por empleadores y clientes.

Certificaciones de ISACA

ISACA es la organización líder mundial en la certificación de profesionales de auditoría de TI, gobierno y seguridad.

Certificación	Nombre	Enfoque	Relevancia para Nicaragua
CISA	Certified Information Systems Auditor	Auditoría de TI, control y seguridad. Es la certificación más reconocida y demandada para auditores de TI a nivel mundial.	Altísima. Las firmas de auditoría, los bancos, las grandes empresas y el sector público valoran enormemente a los profesionales con CISA. Es prácticamente un estándar.

Certificación	Nombre	Enfoque	Relevancia para Nicaragua
CISM	Certified Information Security Manager	Gestión de la seguridad de la información.	Relevante para auditores que se especializan en seguridad o que aspiran a roles de gestión.
CRISC	Certified in Risk and Information Systems Control	Gestión de riesgos de TI y diseño de controles.	Útil para auditores que participan en la identificación y evaluación de riesgos.
CGEIT	Certified in the Governance of Enterprise IT	Gobierno de TI.	Para auditores que asesoran a la alta dirección en el gobierno de TI.

Otras Certificaciones Relevantes

Certificación	Organismo	Enfoque
CIA	The Institute of Internal Auditors (IIA)	Auditoría interna en general (incluye un componente de TI).
ISO 27001 Lead Auditor	IRCA, PECB, etc.	Auditoría de Sistemas de Gestión de Seguridad de la Información basados en ISO 27001.
CISSP	(ISC) ²	Seguridad de la información (más técnico, pero complementario a la auditoría).
ITIL Foundation/Expert	AXELOS	Gestión de servicios de TI.
COBIT Foundation/Implementer	ISACA	Gobierno y gestión de TI basados en COBIT.

Certificación		Organismo	Enfoque
Certificaciones de proveedores		Microsoft, Cisco, Oracle, etc.	Conocimientos técnicos específicos (ej. Microsoft Certified: Azure Security Engineer, CCNA, etc.).

Desafíos del Auditor de TI en el Contexto Nicaragüense

El auditor de TI en Nicaragua enfrenta desafíos particulares que requieren habilidades y adaptaciones específicas:

- Limitaciones de recursos: Muchas organizaciones, especialmente las pequeñas y medianas (PYMES), tienen presupuestos limitados para TI y para auditoría. El auditor debe aprender a priorizar los riesgos más críticos y proponer soluciones costo-efectivas.
- Brecha de talento: Existe una demanda creciente de auditores de TI calificados, pero la oferta de profesionales con certificaciones como CISA aún es limitada en el país. Esto crea oportunidades, pero también presión.
- Entorno normativo en evolución: Leyes como la 1042 (Protección de Datos) son relativamente nuevas y su interpretación y aplicación práctica aún están en desarrollo. El auditor debe mantenerse actualizado y ser capaz de interpretar la norma en el contexto local.
- Riesgos de infraestructura: Nicaragua enfrenta riesgos de desastres naturales (terremotos, huracanes) y una infraestructura eléctrica a veces inestable. La auditoría de continuidad del negocio adquiere una relevancia especial.
- Ciberseguridad creciente: El aumento de los ciberataques a nivel global también afecta a Nicaragua. El auditor debe estar preparado para evaluar la preparación de las organizaciones frente a amenazas como ransomware, phishing y fraudes electrónicos.
- Cultura organizacional: En algunas organizaciones, la auditoría puede ser vista con desconfianza o como un "obstáculo". El auditor necesita habilidades

diplomáticas para construir relaciones y posicionarse como un aliado, no como un enemigo.

El auditor de TI es un profesional polifacético, un "híbrido" que combina el rigor y la metodología del auditor con la comprensión profunda de la tecnología. No basta con saber de computadoras; se requiere integridad, objetividad, pensamiento crítico y habilidades de comunicación. Sus funciones son amplias y van desde la planificación y ejecución de auditorías hasta el asesoramiento a la alta dirección y la investigación de incidentes.

En Nicaragua, la figura del auditor de TI cobra cada vez más importancia, impulsada por la modernización del Estado, la sofisticación del sector financiero, la creciente conciencia sobre la ciberseguridad y las nuevas exigencias legales. Quienes aspiren a esta profesión deben comprometerse con el aprendizaje continuo, la ética profesional y el desarrollo de las habilidades que hemos explorado en este tema. El camino no es fácil, pero es enormemente gratificante para quienes disfrutan del desafío de evaluar, mejorar y proteger el activo más valioso de la era digital: la información.

Autoevaluación

Responde las siguientes preguntas para verificar tu comprensión sobre las características y funciones del auditor de TI.

Pregunta 1:

¿Cuál de las siguientes NO es una característica personal fundamental de un auditor de TI?

- a) Objetividad e independencia
- b) Escepticismo profesional
- c) Conocimiento profundo de programación en todos los lenguajes
- d) Comunicación efectiva

Pregunta 2:

Un auditor de TI descubre información confidencial sobre los planes estratégicos de la empresa durante una auditoría. ¿Qué principio ético debe guiar su actuación?

- a) Objetividad
- b) Confidencialidad
- c) Competencia profesional
- d) Integridad

Pregunta 3:

¿Cuál es la certificación más reconocida a nivel mundial para auditores de TI, emitida por ISACA?

- a) CISSP
- b) CIA
- c) CISA
- d) PMP

Pregunta 4:

Un auditor de TI está revisando el sistema de nómina y encuentra que los salarios de tres gerentes son significativamente más altos que el promedio del mercado. Aunque no hay evidencia de irregularidad, decide profundizar la investigación y solicita ver las autorizaciones de esos salarios. ¿Qué característica está demostrando?

- a) Integridad
- b) Escepticismo profesional
- c) Competencia técnica
- d) Diplomacia

Pregunta 5:

¿Cuál de las siguientes es una función del auditor de TI en la etapa de seguimiento?

- a) Definir el alcance de la auditoría
- b) Redactar el informe final
- c) Verificar que las recomendaciones hayan sido implementadas
- d) Realizar pruebas de vulnerabilidad en los sistemas

Pregunta 6 (Caso práctico):

María es auditora de TI en una empresa nicaragüense. Durante una auditoría, su jefe (el Gerente de Auditoría Interna) le pide que omita un hallazgo importante sobre una debilidad en el sistema de facturación porque "el Gerente de TI es amigo personal del dueño y no queremos problemas". ¿Qué debe hacer María, considerando los principios éticos de la profesión?

- a) Omitir el hallazgo como le pide su jefe.
- b) Omitir el hallazgo pero documentarlo en sus papeles de trabajo "por si acaso".
- c) Incluir el hallazgo en el informe, documentarlo adecuadamente y, si es necesario, escalar el caso al Comité de Auditoría.
- d) Renunciar inmediatamente sin decir nada.

Pregunta 7:

¿Por qué es importante que el auditor de TI en Nicaragua tenga conocimientos de continuidad del negocio?

- a) Porque es un requisito de la certificación CISA.
- b) Porque Nicaragua está expuesta a desastres naturales como terremotos y huracanes que pueden interrumpir las operaciones de TI.
- c) Porque todos los sistemas en Nicaragua son inseguros.
- d) Porque la ley nicaragüense lo exige para todas las empresas.

Modelos, Normas y Estándares de Seguridad Informática y su Relación con la Auditoría de TI

Imaginemos que un auditor de TI llega a una organización y debe evaluar si sus sistemas son seguros. ¿Contra qué los compara? ¿Cómo determina si una configuración es "correcta" o si un control es "suficiente"? No puede basarse en su opinión personal o en lo que "cree" que está bien. Necesita un punto de referencia objetivo, un conjunto de criterios aceptados que le permitan emitir un juicio profesional fundamentado.

Ese punto de referencia son los modelos, normas y estándares. Son como las reglas del juego: definen qué es una buena práctica, qué se considera seguro, cómo se debe gestionar la tecnología y qué controles son necesarios. Para un auditor de TI, conocer estos marcos es tan esencial como un diccionario para un escritor.

En este tema, exploraremos los principales modelos, normas y estándares que rigen el mundo de la seguridad informática y la gestión de TI. Aprenderemos a diferenciarlos, comprenderemos su propósito y, lo más importante, veremos cómo el auditor de TI los utiliza como criterio de auditoría para evaluar la realidad de una organización y determinar si cumple o no con lo esperado.

Conceptos Fundamentales: Diferencia entre Modelo, Norma y Estándar

Antes de adentrarnos en los marcos específicos, es crucial entender la diferencia entre estos tres conceptos, que a menudo se usan de manera intercambiable pero tienen significados distintos.

Concepto	Definición	Analogía	Ejemplo en TI
Modelo (o Marco de Trabajo)	Es un conjunto de buenas prácticas, principios y procesos agrupados de manera estructurada. No es obligatorio, sino una guía o referencia que las organizaciones pueden adoptar voluntariamente para mejorar su gestión.	Es como un mapa de carreteras : te muestra diferentes rutas para llegar a un destino, pero no te obliga a tomar una en particular.	COBIT, ITIL, COSO. Son marcos que proponen cómo hacer las cosas, pero cada organización los adapta a su realidad.
Norma	Es un documento establecido por consenso y aprobado por un organismo reconocido (como ISO), que proporciona reglas, directrices o características para que las actividades o sus resultados sean óptimos. Su cumplimiento puede ser voluntario u obligatorio (si se adopta como requisito legal o contractual).	Es como una receta de cocina estandarizada : si sigues los ingredientes y pasos al pie de la letra, obtendrás un plato con características predecibles y de calidad.	ISO/IEC 27001. Es una norma que especifica los requisitos para un Sistema de Gestión de Seguridad de la Información (SGSI). Una organización puede certificarse en ella.
Estándar (o Especificación Técnica)	Es un documento que establece especificaciones técnicas, métodos de prueba, terminología,	Es como las especificaciones de un tornillo : define el diámetro, el paso de rosca, el tipo de cabeza,	PCI DSS (estándar de seguridad para tarjetas de pago), IEEE 802.11 (estándar para redes Wi-Fi). Definen "cómo"

Concepto	Definición	Analogía	Ejemplo en TI
	etc., para un producto, proceso o servicio. Puede ser desarrollado por organismos de estandarización, consorcios industriales o incluso empresas.	para que cualquier tornillo fabricado bajo ese estándar sea intercambiable.	deben ser las cosas a nivel técnico.

En resumen:

- Un modelo te dice "por dónde puedes ir" (guía).
- Una norma te dice "lo que debes hacer para lograr algo" (requisitos).
- Un estándar te dice "cómo debe ser algo" (especificaciones técnicas).
- Para el auditor de TI, estos tres elementos son fundamentales, ya que le proporcionan los criterios contra los cuales comparará la evidencia que recolecte.

Principales Modelos (Marcos de Referencia) para la Auditoría y Gestión de TI

COBIT (Control Objectives for Information and Related Technologies)

Es, sin duda, el marco de referencia más importante para el auditor de TI. Desarrollado por ISACA, COBIT proporciona un conjunto integral de objetivos de control, buenas prácticas y modelos de madurez para el gobierno y la gestión de las TI empresariales.

Evolución de COBIT:

VERSIÓN	AÑO	CARACTERÍSTICAS PRINCIPALES
COBIT 1	1996	Enfoque en auditoría: proporcionaba un conjunto de objetivos de control para que los auditores evaluaran los sistemas.
COBIT 2	1998	Amplió su enfoque al control, incluyendo guías de implementación.
COBIT 3	2000	Introdujo el concepto de "gerencia" y modelos de madurez.
COBIT 4.0/4.1	2005/2007	Se consolidó como un marco integral de gobierno de TI, alineando los objetivos de control con los objetivos del negocio. Muy utilizado aún en muchas organizaciones.
COBIT 5	2012	Dio un salto cualitativo al integrar todos los marcos de ISACA (Val IT, Risk IT) y basarse en principios holísticos. Se enfoca en que TI gestione la información para crear valor al negocio.
COBIT 2019	2018	La versión más reciente. Es más flexible, actualizable y se adapta mejor a las necesidades específicas de cada organización, introduciendo "factores de diseño" que permiten personalizar el sistema de gobierno.

Principios de COBIT 5 (aún muy vigentes como base conceptual):

1. Satisfacer las Necesidades de los Grupos de Interés: COBIT 5 parte de los grupos de interés (stakeholders) y traduce sus necesidades en metas corporativas, luego en metas de TI y finalmente en metas de los procesos.
2. Cubrir la Empresa de Extremo a Extremo: No se enfoca solo en la función de TI, sino que integra el gobierno y la gestión de TI en toda la organización.
3. Aplicar un Marco de Referencia Único e Integrado: COBIT 5 integra los principales marcos de ISACA y otros (como ITIL, ISO 27001), actuando como un paraguas.
4. Habilitar un Enfoque Holístico: Define un conjunto de habilitadores (factores que influyen en el éxito del gobierno y la gestión de TI):
 - Principios, Políticas y Marcos.
 - Procesos.
 - Estructuras Organizativas.
 - Cultura, Ética y Comportamiento.
 - Información.
 - Servicios, Infraestructura y Aplicaciones.
 - Personas, Habilidades y Competencias.
5. Separar el Gobierno de la Gestión:
 - Gobierno: Evalúa las necesidades de los grupos de interés, dirige la estrategia y supervisa el desempeño (responsabilidad de la alta dirección).
 - Gestión: Planifica, construye, ejecuta y monitorea las actividades de acuerdo con la dirección establecida por el gobierno (responsabilidad de la gerencia).

Modelo de Procesos de COBIT 5 y COBIT 2019:

COBIT organiza los procesos en dos grandes dominios:

1. Dominios de Gobierno: Evaluar, Dirigir y Supervisar (EDM): Procesos relacionados con el gobierno de TI.
2. Dominios de Gestión:
 - Alinear, Planificar y Organizar (APO): Estrategia, arquitectura, innovación, presupuesto, riesgos, calidad.
 - Construir, Adquirir e Implementar (BAI): Desarrollo de soluciones, gestión de cambios, gestión de proyectos, capacidad.
 - Entregar, Dar Servicio y Soportar (DSS): Operaciones, seguridad, continuidad, atención a usuarios.
 - Supervisar, Evaluar y Valorar (MEA): Monitoreo del desempeño, control interno, cumplimiento.

Uso de COBIT por el Auditor de TI:

Un auditor de TI que trabaja en el Banco Central de Nicaragua (BCN) utiliza COBIT como marco de referencia para evaluar los procesos de TI. Por ejemplo, para auditar el proceso de gestión de cambios (BAI06 en COBIT 5), el auditor revisará si existen procedimientos formales, si los cambios son autorizados por un comité, si se prueban antes de pasar a producción y si se documentan adecuadamente. COBIT le proporciona los criterios específicos contra los cuales comparar lo que encuentra en el BCN.

ITIL (Information Technology Infrastructure Library)

ITIL es el marco de referencia más utilizado a nivel mundial para la gestión de servicios de TI. Se enfoca en alinear los servicios de TI con las necesidades del negocio, mejorando la eficiencia, la calidad del servicio y la satisfacción del cliente.

Evolución de ITIL:

- ITIL v2: Se centraba en dos grandes áreas: Soporte del Servicio y Entrega del Servicio.
- ITIL v3 (2007, actualizada en 2011): Introdujo el concepto de ciclo de vida del servicio, con cinco publicaciones centrales: Estrategia del Servicio, Diseño del Servicio, Transición del Servicio, Operación del Servicio y Mejora Continua del Servicio.
- ITIL 4 (2019): La versión más reciente. Se adapta a las nuevas metodologías (ágiles, DevOps, Lean) y al valor de la co-creación con el cliente. Define un Sistema de Valor del Servicio (SVS) y 34 prácticas de gestión agrupadas en tres categorías: General, de Servicio y Técnicas.

Conceptos Clave de ITIL 4:

- Cadena de Valor del Servicio: Un modelo operativo que describe las actividades clave necesarias para responder a la demanda y facilitar la creación de valor a través de los servicios.
- Prácticas: Conjuntos de recursos organizacionales diseñados para realizar un trabajo o cumplir un objetivo. Algunas prácticas relevantes para el auditor de TI son:
 - Gestión de Incidentes: Restaurar el servicio normal lo antes posible.
 - Gestión de Problemas: Identificar y eliminar las causas raíz de los incidentes.
 - Gestión de Cambios: Controlar los cambios en la infraestructura y servicios.
 - Gestión de Niveles de Servicio: Negociar, acordar y monitorear los acuerdos de nivel de servicio (SLA).

- Gestión de la Continuidad del Servicio: Gestionar los riesgos que podrían afectar gravemente al servicio.
- Monitoreo y Gestión de Eventos: Monitorear servicios e infraestructura para detectar y gestionar eventos.

Uso de ITIL por el Auditor de TI:

Un auditor revisando el área de soporte técnico de una empresa como Claro Nicaragua o Tigo utilizaría ITIL como marco. Evaluaría si los incidentes reportados por los clientes se registran adecuadamente, si se clasifican por prioridad, si se les da seguimiento hasta su resolución, y si se miden los tiempos de respuesta y resolución conforme a los SLA. También revisaría si existe un proceso de gestión de problemas que analice incidentes recurrentes para encontrar la causa raíz.

COSO (Committee of Sponsoring Organizations of the Treadway Commission)

Como vimos en el tema 1.4, COSO es el marco de referencia para el control interno. Aunque no es exclusivo de TI, es fundamental porque proporciona la base conceptual sobre cómo deben diseñarse y evaluarse los controles en toda la organización, incluyendo los de TI.

Relación COSO - Auditoría de TI:

El auditor de TI utiliza COSO para:

- Evaluar el ambiente de control en el área de TI.
- Identificar los riesgos tecnológicos que pueden afectar los objetivos de la organización.
- Verificar que las actividades de control en TI (tanto generales como de aplicación) estén diseñadas e implementadas adecuadamente.
- Evaluar la calidad de la información y comunicación generada por los sistemas.
- Revisar las actividades de supervisión y monitoreo sobre los controles de TI.

Principales Normas y Estándares de Seguridad Informática

Familia ISO/IEC 27000

Es la familia de normas más importante a nivel internacional para la seguridad de la información. Desarrollada por la Organización Internacional de Normalización (ISO) y la Comisión Electrotécnica Internacional (IEC).

NORMA	NOMBRE	DESCRIPCIÓN	RELEVANCIA PARA AUDITORÍA DE TI
ISO/IEC 27000	Visión general y vocabulario	Proporciona una introducción a la familia y define los términos fundamentales.	Útil para entender la terminología.
ISO/IEC 27001	Requisitos para un Sistema de Gestión de Seguridad de la Información (SGSI)	Es la norma certificable . Especifica los requisitos para establecer, implementar, mantener y mejorar un SGSI. Incluye un Anexo A con 114 controles agrupados en 14 dominios.	Un auditor puede auditar a una organización para certificarla en ISO 27001, o utilizar la norma como criterio para evaluar la madurez de su SGSI.
ISO/IEC 27002	Código de buenas prácticas para los controles de seguridad de la información	Es una guía de implementación de los controles del Anexo A de la 27001. No es certificable.	Ayuda al auditor a entender cómo deberían implementarse los controles en la práctica.
ISO/IEC 27005	Gestión del riesgo en la seguridad de la información	Proporciona directrices para la gestión de riesgos de seguridad de la información.	Útil para evaluar si la organización tiene un proceso formal de gestión de riesgos.
ISO/IEC 27031	Directrices para la continuidad del negocio en TI	Se enfoca en la preparación de TI para la continuidad del negocio.	Fundamental para auditar planes de continuidad y recuperación ante desastres.
ISO/IEC 27701	Extensión de la 27001 para la gestión de la privacidad de la información	Especifica requisitos para un Sistema de Gestión de Información de Privacidad (SGIP).	Muy relevante para auditar el cumplimiento de leyes de protección de datos como la Ley 1042 en Nicaragua.

Los 14 Dominios de Control del Anexo A de ISO 27001:

1. Políticas de seguridad de la información.
2. Organización de la seguridad de la información.
3. Seguridad de los recursos humanos.
4. Gestión de activos.
5. Control de accesos.
6. Criptografía.
7. Seguridad física y ambiental.
8. Seguridad de las operaciones.
9. Seguridad de las comunicaciones.
10. Adquisición, desarrollo y mantenimiento de sistemas.
11. Relaciones con los proveedores.
12. Gestión de incidentes de seguridad.
13. Aspectos de seguridad en la gestión de la continuidad del negocio.
14. Cumplimiento.

Ejemplo de auditoría ISO 27001:

Una empresa de servicios BPO (Business Process Outsourcing) ubicada en zona franca, que maneja datos de clientes extranjeros, decide certificarse en ISO 27001 para demostrar que protege adecuadamente la información. Un auditor de TI (certificado como Lead Auditor ISO 27001) es contratado para realizar la auditoría de certificación. Revisará, por ejemplo, el dominio de Control de Accesos: verificará si existe una política de control de acceso, si los usuarios tienen perfiles de acceso definidos, si se revisan periódicamente los permisos, si se utiliza autenticación multifactor para accesos remotos, etc.

PCI DSS (Payment Card Industry Data Security Standard)

No es una norma ISO, sino un estándar creado por el Consejo de Normas de Seguridad de la Industria de Tarjetas de Pago (PCI SSC), fundado por las principales marcas de tarjetas (Visa, MasterCard, American Express, Discover, JCB). Es de cumplimiento obligatorio para cualquier organización que almacene, procese o transmita datos de titulares de tarjetas.

Objetivo: Proteger los datos de las tarjetas de pago y reducir el fraude.

Estructura: PCI DSS v3.2.1 (aún vigente, aunque ya existe v4.0) se organiza en 6 objetivos de control y 12 requisitos:

Objetivo	Requisitos
1. Construir y Mantener Redes y Sistemas Seguros	1. Instalar y mantener configuraciones de firewall para proteger los datos del titular de la tarjeta. 2. No usar valores predeterminados proporcionados por el proveedor para contraseñas del sistema y otros parámetros de seguridad.
2. Proteger los Datos del Titular de la Tarjeta	3. Proteger los datos del titular de la tarjeta almacenados. 4. Cifrar la transmisión de los datos del titular de la tarjeta a través de redes públicas abiertas.
3. Mantener un Programa de Gestión de Vulnerabilidades	5. Proteger todos los sistemas contra malware y actualizar periódicamente el software antivirus. 6. Desarrollar y mantener sistemas y aplicaciones seguros.
4. Implementar Medidas Sólidas de Control de Acceso	7. Restringir el acceso a los datos del titular de la tarjeta según la necesidad de conocer. 8. Identificar y autenticar el acceso a los componentes del sistema. 9. Restringir el acceso físico a los datos del titular de la tarjeta.

Objetivo	Requisitos
5. Monitorear y Probar las Redes Regularmente	10. Rastrear y monitorear todo el acceso a los recursos de red y a los datos del titular de la tarjeta. 11. Probar regularmente los sistemas y procesos de seguridad.
6. Mantener una Política de Seguridad de la Información	12. Mantener una política que aborde la seguridad de la información para todo el personal.

Ejemplo de auditoría PCI DSS:

Yamatú, como comercio electrónico que acepta pagos con tarjeta, debe cumplir con PCI DSS. Un auditor de TI especializado (QS A - Qualified Security Assessor) realizaría una auditoría para verificar, por ejemplo:

- Si el formulario de pago en la web está embebido de forma segura o redirige a un iframe seguro.
- Si los números de tarjeta (PAN) se almacenan cifrados o, mejor aún, si no se almacenan (tokenización).
- Si la red que procesa los pagos está segmentada (aislada) de la red corporativa general.
- Si se realizan escaneos de vulnerabilidades trimestrales y pruebas de penetración anuales.

NIST (National Institute of Standards and Technology)

El NIST es una agencia del Departamento de Comercio de Estados Unidos. Publica una amplia gama de estándares y guías técnicas, muchas de las cuales se han convertido en referentes mundiales, especialmente en ciberseguridad.

Publicaciones clave del NIST para el auditor de TI:

PUBLICACIÓN	NOMBRE	DESCRIPCIÓN
NIST SP 800-53	Security and Privacy Controls for Information Systems and Organizations	Un catálogo extenso de controles de seguridad y privacidad para sistemas de información federales de EE.UU., pero utilizado como referencia global.
NIST CYBERSECURITY FRAMEWORK (CSF)	Marco de Ciberseguridad del NIST	Desarrollado en colaboración con la industria, es un marco voluntario basado en estándares, guías y prácticas existentes para ayudar a las organizaciones a gestionar y reducir el riesgo de ciberseguridad. Se organiza en cinco funciones: Identificar, Proteger, Detectar, Responder y Recuperar.
NIST SP 800-30	Guide for Conducting Risk Assessments	Guía detallada para realizar evaluaciones de riesgos.
NIST SP 800-34	Contingency Planning Guide for Federal Information Systems	Guía para la planificación de contingencias y recuperación ante desastres.

Uso de NIST:

Aunque son publicaciones del gobierno de EE.UU., muchas empresas multinacionales y organizaciones en Nicaragua que trabajan con estándares internacionales adoptan el NIST Cybersecurity Framework como modelo para evaluar y mejorar su postura de ciberseguridad. Un auditor podría utilizarlo para evaluar la madurez de las capacidades de una organización en las cinco funciones del marco.

Normativas y Estándares Específicos para Nicaragua

El auditor de TI en Nicaragua debe conocer y aplicar las normativas locales que son de cumplimiento obligatorio para ciertos sectores.

Normas de Auditoría Gubernamental de Nicaragua (NAGUN)

Emitidas por la Contraloría General de la República (CGR), las NAGUN son de cumplimiento obligatorio para todas las entidades del sector público en Nicaragua (ministerios, alcaldías, empresas del estado, etc.). Establecen los lineamientos para la práctica de la auditoría gubernamental, incluyendo disposiciones específicas para la auditoría de sistemas de información.

Aspectos clave de las NAGUN para el auditor de TI:

- Definen los principios, normas y procedimientos que deben seguir los auditores gubernamentales.
- Incluyen secciones específicas sobre la evaluación del control interno en entornos informatizados.
- Establecen requisitos para la revisión de la seguridad de los sistemas de información públicos.
- Regulan la elaboración y presentación de informes de auditoría en el sector público.

Ejemplo de aplicación de NAGUN:

Un auditor de la CGR (o un auditor externo contratado por una alcaldía) que audita el sistema de recaudación de impuestos de la Alcaldía de Granada debe hacerlo siguiendo las NAGUN. Sus procedimientos de auditoría, la forma de documentar los hallazgos y la estructura de su informe deben ajustarse a lo que establece esta normativa.

Normativas de la SIBOIF (Superintendencia de Bancos y de Otras Instituciones Financieras)

La SIBOIF es el ente regulador del sistema financiero nicaragüense. Emite normas, resoluciones y circulares que son de cumplimiento obligatorio para bancos, financieras, cooperativas de ahorro y crédito supervisadas, casas de cambio, etc.

Normativas relevantes para TI:

- Norma sobre Gestión de Riesgos de Tecnologías de Información: Establece los requisitos mínimos que las entidades financieras deben cumplir para gestionar los riesgos asociados al uso de TI, incluyendo seguridad de la información, continuidad del negocio, gestión de proyectos, etc.
- Norma sobre Gestión de Seguridad de la Información: Profundiza en los controles específicos de seguridad que deben implementar las entidades financieras.
- Norma para la Gestión del Riesgo de Lavado de Activos y Financiamiento al Terrorismo: Incluye requisitos sobre los sistemas de información utilizados para el monitoreo de transacciones sospechosas.

Ejemplo de aplicación de normas SIBOIF:

Un auditor de TI que trabaja en el departamento de auditoría interna de FICOHSA debe conocer a fondo las normativas de la SIBOIF. En su auditoría anual, verificará que el banco cumple con los requisitos de la "Norma sobre Gestión de Riesgos de Tecnologías de Información", por ejemplo, en cuanto a la existencia de un plan de continuidad del negocio probado y actualizado.

Ley No. 1042, Ley de Protección de Datos Personales

Aprobada en 2020, esta ley regula el tratamiento de los datos personales en Nicaragua. Establece principios, derechos de los titulares de los datos (ARCO: Acceso, Rectificación, Cancelación y Oposición) y obligaciones para los responsables y encargados del tratamiento.

Implicaciones para la Auditoría de TI:

El auditor de TI debe verificar que la organización cumpla con:

- Principio de seguridad de los datos: Implementar las medidas técnicas y organizativas necesarias para proteger los datos personales contra pérdida, alteración, acceso no autorizado, etc. (ISO 27001 es una excelente referencia).
- Deber de confidencialidad: Garantizar que quienes acceden a los datos están sujetos a obligación de confidencialidad.
- Notificación de vulneraciones: Establecer procedimientos para notificar a la autoridad (ARESEP) y a los afectados en caso de violaciones de seguridad.
- Consentimiento informado: Verificar que los sistemas capturen y almacenen adecuadamente los consentimientos de los titulares para el tratamiento de sus datos.
- Registro de bases de datos: Asegurar que las bases de datos que contienen datos personales estén registradas ante la autoridad competente.

Ejemplo de auditoría de cumplimiento de Ley 1042:

Una clínica médica privada en Managua maneja historiales clínicos de sus pacientes (datos sensibles). Un auditor de TI revisaría si la clínica tiene medidas de seguridad (cifrado, control de accesos) para proteger esos datos, si los pacientes firman un consentimiento informado que se almacena digitalmente, y si la base de datos de pacientes está registrada ante la ARESEP.

Relación de los Modelos, Normas y Estándares con la Auditoría de TI

¿Cómo utiliza el auditor de TI todo este arsenal de marcos? Básicamente, de dos maneras:

Como criterio de auditoría: Son la "ley" contra la cual el auditor compara la realidad de la organización. Por ejemplo, si está auditando la seguridad de una aplicación que procesa pagos con tarjeta, su criterio serán los 12 requisitos de PCI DSS. Si está auditando el proceso de gestión de cambios en un banco, su criterio pueden ser las buenas prácticas de COBIT y las normas de la SIBOIF.

Como guía para la evaluación: Le ayudan a saber qué preguntar, qué revisar y qué esperar. Un auditor que conoce ITIL sabe que en un proceso de gestión de incidentes debe verificar si existe una base de datos de errores conocidos (KEDB) y si se clasifican los incidentes por prioridad. Un auditor que conoce ISO 27001 sabe que al revisar el control de accesos debe verificar si existen políticas, si se revisan periódicamente los permisos y si se eliminan las cuentas de usuarios que ya no trabajan en la organización.

Esquema de la relación:

flowchart LR

```
A[Organización Auditada<br/>(Realidad actual)] --> B[AUDITOR DE TI]
C[MODELOS<br/>COBIT, ITIL, COSO...] --> B
D[NORMAS Y ESTÁNDARES<br/>ISO 27001, PCI DSS,<br/>NAGUN, SIBOIF, Ley 1042...]
--> B
B --> E[Comparación<br/>Realidad vs. Criterio]
E --> F[HALLAZGOS DE AUDITORÍA<br/>(Cumple / No cumple /<br/>Debe mejorar)]
F --> G[Recomendaciones<br/>basadas en buenas prácticas]
```

Los modelos, normas y estándares son el lenguaje común y el punto de referencia que da sentido y rigor al trabajo del auditor de TI. Sin ellos, la auditoría sería una opinión subjetiva sin fundamento. Con ellos, se convierte en una evaluación profesional, objetiva y comparable.

Un buen auditor de TI no solo conoce estos marcos, sino que sabe cuál aplicar en cada contexto, cómo interpretarlos y cómo utilizarlos para generar valor para la organización. Desde los modelos holísticos como COBIT, pasando por las normas certificables como ISO 27001, hasta los estándares sectoriales como PCI DSS y las normativas locales como NAGUN y las de la SIBOIF, todos son herramientas indispensables en la caja de herramientas del auditor.

En un mundo cada vez más regulado y con mayores exigencias de seguridad y transparencia, el dominio de estos marcos se convierte en una ventaja competitiva y en un sello de profesionalismo para cualquier auditor de TI, especialmente en el contexto nicaragüense, donde la convergencia de normativas locales e internacionales plantea desafíos y oportunidades únicos.

Autoevaluación

Responde las siguientes preguntas para verificar tu comprensión sobre los modelos, normas y estándares y su relación con la auditoría de TI.

Pregunta 1:

¿Cuál es la principal diferencia entre un modelo (como COBIT) y una norma (como ISO 27001)?

- a) El modelo es de cumplimiento obligatorio y la norma es voluntaria.
- b) El modelo es una guía de buenas prácticas, mientras que la norma establece requisitos certificables.
- c) El modelo solo aplica al sector público y la norma al sector privado.
- d) No hay diferencia, son términos sinónimos.

Pregunta 2:

¿Qué estándar es de cumplimiento obligatorio para cualquier organización que procese pagos con tarjeta de crédito o débito?

- a) ISO 27001
- b) COBIT
- c) PCI DSS
- d) ITIL

Pregunta 3:

Si un auditor de TI en Nicaragua está evaluando el sistema de gestión de seguridad de la información de una empresa para certificarla, ¿qué norma utilizará principalmente como criterio?

- a) COBIT 2019
- b) NAGUN
- c) ISO/IEC 27001
- d) Ley 1042

Pregunta 4:

¿Cuál de las siguientes es una normativa de cumplimiento obligatorio para las entidades del sector público en Nicaragua en materia de auditoría?

- a) PCI DSS
- b) NIST SP 800-53
- c) NAGUN (Normas de Auditoría Gubernamental de Nicaragua)
- d) ITIL 4

Pregunta 5:

Un auditor de TI está revisando el proceso de gestión de incidentes de una empresa de telecomunicaciones en Nicaragua. Quiere evaluar si el proceso sigue las mejores

prácticas internacionales. ¿Qué marco de referencia sería el más apropiado para obtener criterios de auditoría?

- a) COSO
- b) ITIL
- c) PCI DSS
- d) Ley 1042

Pregunta 6:

La Ley No. 1042 de Protección de Datos Personales en Nicaragua exige que las organizaciones implementen medidas de seguridad para proteger los datos personales. ¿Qué norma internacional es una referencia ideal para diseñar e implementar esas medidas y, por tanto, para auditar su cumplimiento?

- a) COBIT
- b) ITIL
- c) ISO/IEC 27001
- d) NAGUN

Pregunta 7 (Caso práctico):

Imagina que trabajas como auditor de TI en la Superintendencia de Bancos (SIBOIF) y debes supervisar a un banco nicaragüense. ¿Qué marcos, normas y estándares deberías conocer y aplicar en tu auditoría? (Selecciona la opción que incluya los más relevantes para este contexto).

- a) ITIL y PCI DSS únicamente.
- b) Las normativas de la SIBOIF, COBIT (como marco de gobierno) e ISO 27001 (como referencia para seguridad).
- c) Solo las NAGUN, porque es una entidad pública.
- d) PCI DSS y Ley 1042 exclusivamente.

Pregunta 8:

¿Cuál de los siguientes NO es un dominio de control del Anexo A de ISO 27001?

- a) Control de accesos
- b) Gestión de incidentes de seguridad
- c) Gestión de niveles de servicio (SLA)
- d) Criptografía

Evaluación Integral de la Unidad

Esta evaluación tiene como propósito verificar la comprensión y aplicación de los conceptos fundamentales abordados en la Unidad I. A lo largo de seis temas, hemos explorado:

- Tema 1.1: Conceptos generales de auditoría y TI
- Tema 1.2: Antecedentes y orígenes de la auditoría
- Tema 1.3: Tipos de auditoría en Tecnologías de Información
- Tema 1.4: Control interno y auditoría de TI
- Tema 1.5: Características y funciones del auditor de TI
- Tema 1.6: Modelos, normas y estándares de seguridad informática

La evaluación consta de cinco secciones que combinan preguntas teóricas, casos prácticos contextualizados en Nicaragua, análisis de situaciones reales y ejercicios de reflexión. El objetivo no es solo memorizar conceptos, sino demostrar la capacidad para aplicarlos en contextos profesionales concretos.

Sección 1: Preguntas de Selección Múltiple (20 puntos)

Instrucciones: Selecciona la opción que mejor responda cada pregunta. Cada respuesta correcta vale 2 puntos.

1.1. El término "auditoría" proviene del latín audire, que significa:

- a) Escribir
- b) Verificar
- c) Oír
- d) Calcular

1.2. ¿Cuál de los siguientes hitos históricos impulsó significativamente la demanda de auditores de TI a nivel global?

- a) La invención del telégrafo en el siglo XIX

- b) La creación de la primera computadora personal por IBM en 1981
- c) La ley Sarbanes-Oxley (SOX) en 2002, que exigió controles sobre los sistemas que soportan información financiera
- d) El desarrollo del primer navegador web en 1993

1.3. Un auditor de TI que verifica si una empresa nicaragüense cumple con las disposiciones de la Ley No. 1042 de Protección de Datos Personales está realizando una auditoría de:

- a) Seguridad informática
- b) Cumplimiento normativo en TI
- c) Sistemas o aplicaciones
- d) Continuidad del negocio

1.4. En el modelo COSO, ¿cuál de los siguientes NO es uno de sus cinco componentes del control interno?

- a) Ambiente de control
- b) Evaluación de riesgos
- c) Gestión de proveedores
- d) Actividades de control

1.5. ¿Cuál es la certificación profesional más reconocida a nivel mundial para auditores de TI, emitida por ISACA?

- a) CISSP
- b) PMP
- c) CISA
- d) ITIL Foundation

1.6. Una empresa nicaragüense que procesa pagos con tarjetas de crédito y débito debe cumplir obligatoriamente con el siguiente estándar de seguridad:

- a) ISO 27001

- b) COBIT 2019
- c) PCI DSS
- d) NAGUN

1.7. La principal diferencia entre un modelo (como COBIT) y una norma (como ISO 27001) es que:

- a) El modelo es de cumplimiento obligatorio y la norma es voluntaria
- b) El modelo es una guía de buenas prácticas, mientras que la norma establece requisitos certificables
- c) El modelo solo aplica al sector público y la norma al sector privado
- d) El modelo es más antiguo que la norma

1.8. Si un auditor de TI verifica que todas las solicitudes de cambio a un sistema hayan sido aprobadas por el comité de cambios antes de implementarse, ¿qué tipo de prueba está realizando?

- a) Prueba sustantiva
- b) Prueba de cumplimiento (o de controles)
- c) Prueba de integridad de datos
- d) Prueba de recorrido (walkthrough)

1.9. ¿Cuál de las siguientes es una característica personal fundamental de un auditor de TI?

- a) Conocimiento profundo de todos los lenguajes de programación
- b) Escepticismo profesional
- c) Habilidad para vender productos tecnológicos
- d) Especialización exclusiva en hardware

1.10. Las Normas de Auditoría Gubernamental de Nicaragua (NAGUN) son de cumplimiento obligatorio para:

- a) Todas las empresas privadas en Nicaragua

- b) Únicamente los bancos y financieras
- c) Las entidades del sector público (ministerios, alcaldías, etc.)
- d) Las empresas de zonas francas

Sección 2: Términos Pareados (15 puntos)

Instrucciones: Relaciona cada concepto de la columna izquierda con su descripción correcta en la columna derecha. Escribe la letra correspondiente en el paréntesis. Cada relación correcta vale 1.5 puntos.

CONCEPTO	DESCRIPCIÓN
2.1. COBIT ()	A. Norma internacional certificable para Sistemas de Gestión de Seguridad de la Información.
2.2. ITIL ()	B. Marco de referencia para el control interno, ampliamente utilizado en auditoría financiera y de TI.
2.3. ISO 27001 ()	C. Profesional que evalúa los sistemas de información con independencia y objetividad.
2.4. PCI DSS ()	D. Ley nicaragüense que regula el tratamiento de los datos personales.
2.5. COSO ()	E. Conjunto de buenas prácticas para la gestión de servicios de TI.
2.6. AUDITOR DE TI ()	F. Marco de gobierno y gestión de TI desarrollado por ISACA, muy utilizado por auditores.
2.7. LEY 1042 ()	G. Estándar de seguridad obligatorio para quienes procesan pagos con tarjeta.
2.8. CONTROLES GENERALES DE TI ()	H. Controles que aplican a todas las áreas de TI (seguridad lógica, gestión de cambios, etc.).
2.9. SEGREGACIÓN DE FUNCIONES ()	I. Principio de control interno que evita que una persona tenga todas las capacidades para cometer y ocultar un fraude.
2.10. AUDITORÍA FORENSE INFORMÁTICA ()	J. Rama de la auditoría de TI que investiga incidentes con posibles implicaciones legales.

Sección 3: Preguntas de Desarrollo Corto (20 puntos)

Instrucciones: Responde de manera clara y concisa cada pregunta. Cada respuesta correcta y bien fundamentada vale 4 puntos.

1. Explica brevemente la diferencia entre auditar "alrededor" del ordenador y auditar "a través" del ordenador. ¿Por qué fue necesario este cambio de enfoque?
2. Menciona y describe al menos tres de los cinco componentes del modelo COSO de control interno.
3. ¿Cuáles son los tres principios fundamentales del modelo CIA (Confidencialidad, Integridad, Disponibilidad) en seguridad de la información? Proporciona un ejemplo de cada uno aplicado a una entidad gubernamental nicaragüense (como una alcaldía).
4. ¿Qué es la segregación de funciones y por qué es un control interno tan importante en el entorno de TI? Pon un ejemplo de lo que podría ocurrir si no existe en un sistema de nómina.
5. Describe al menos tres funciones principales que realiza un auditor de TI durante el proceso de auditoría (no es necesario que sean en orden cronológico).

Sección 4: Casos Prácticos Contextualizados en Nicaragua (30 puntos)

Instrucciones: Analiza cada caso y responde las preguntas planteadas. Demuestra tu capacidad para aplicar los conceptos de la unidad a situaciones reales. Cada caso vale 10 puntos.

Caso 1: La Cooperativa de Ahorro y Crédito "Progressa"

La Cooperativa de Ahorro y Crédito "Progressa" opera en la ciudad de Estelí. Tiene más de 15,000 socios y maneja depósitos por aproximadamente 250 millones de córdobas. Recientemente, la Superintendencia de Bancos (SIBOIF) ha emitido una nueva circular que exige a las cooperativas supervisadas implementar controles más estrictos sobre sus sistemas de información, incluyendo:

- Autenticación multifactor para accesos remotos.
- Pruebas anuales de recuperación ante desastres.
- Designación de un oficial de seguridad de la información.

El Consejo de Administración de la cooperativa te ha contratado como consultor externo para que les ayudes a entender lo que deben hacer y para que realices una evaluación inicial de su situación actual.

Preguntas:

- a) ¿Qué tipo de auditoría de TI necesitaría realizar "Progressa" para verificar que cumple con la nueva circular de la SIBOIF? Justifica tu respuesta. (2 puntos)
- b) La cooperativa tiene un solo servidor en un pequeño cuarto sin control de temperatura, sin puerta con cerradura especial y con los backups almacenados en el mismo estante. ¿Qué tipo de control general de TI es deficiente y por qué es crítico para una entidad financiera? (3 puntos)
- c) Menciona al menos dos marcos, normas o estándares (de los estudiados en la unidad) que podrían servirle a "Progressa" como guía para implementar las mejoras exigidas por la SIBOIF. Explica brevemente por qué cada uno sería útil. (3 puntos)

d) Si la cooperativa sufriera un incendio que destruyera su único servidor, ¿qué principio fundamental de seguridad de la información (CIA) se vería más afectado y qué plan debería haber tenido para mitigar este riesgo? (2 puntos)

Caso 2: El Ministerio de Educación y el Sistema de Matrícula Escolar

El Ministerio de Educación (MINED) de Nicaragua implementó un nuevo sistema en línea para que los padres de familia puedan matricular a sus hijos en las escuelas públicas. El sistema almacena datos personales de los niños y sus padres (nombres, direcciones, cédulas de identidad, etc.). Un periodista ha denunciado en un noticiero que, según una "fuente anónima", el sistema tiene graves fallas de seguridad y que alguien podría acceder a los datos de todos los estudiantes.

La Ministra de Educación, preocupada por el escándalo y las posibles implicaciones legales, ordena una investigación urgente.

Preguntas:

- a) Además de la Contraloría General de la República (CGR), ¿qué otro ente regulador en Nicaragua podría estar interesado en esta situación, considerando la naturaleza de los datos afectados? ¿Por qué? (2 puntos)
- b) ¿Qué tipo de auditoría de TI sería la más adecuada para investigar si la denuncia del periodista es cierta y, de serlo, determinar el alcance del posible acceso no autorizado? (2 puntos)
- c) Si se confirma que el sistema permitía acceder a datos personales sin autenticación adecuada, ¿qué ley nicaragüense se estaría incumpliendo y qué principios del modelo CIA se habrían vulnerado? (3 puntos)
- d) El MINED necesita demostrar a la ciudadanía que ha corregido los problemas y que ahora la información está segura. ¿Qué certificación internacional (norma) podría buscar el MINED para acreditar que ha implementado un Sistema de Gestión de Seguridad de la Información robusto? (1 punto)
- e) ¿Qué papel debería jugar el auditor interno de TI del MINED en este proceso, una vez que se haya superado la crisis inmediata? (2 puntos)

Caso 3: El Auditor Interno de "Distribuidora Nicaragüense S.A."

Carlos es el auditor de TI de Distribuidora Nicaragüense S.A. , una empresa mediana dedicada a la importación y distribución de productos de consumo masivo en todo el país. La empresa utiliza un sistema ERP (Planificación de Recursos Empresariales) que gestiona inventarios, facturación, cuentas por cobrar y nómina.

Durante una auditoría de rutina al módulo de facturación, Carlos descubre lo siguiente:

- Un vendedor, Luis, ha estado aplicando descuentos especiales del 20% a ciertos clientes, cuando la política de la empresa establece que los vendedores solo pueden autorizar descuentos de hasta el 5% sin aprobación del gerente comercial.
- El sistema no registra en ningún log quién aplica los descuentos ni cuándo se aplican. Solo queda reflejado el precio final de la factura.
- Carlos entrevista a Luis, quien le dice que "siempre lo ha hecho así" y que "el gerente comercial lo sabe y está de acuerdo", pero Carlos no encuentra ninguna evidencia documental de esa autorización.
- El gerente comercial, al ser consultado, dice que no recuerda haber autorizado esos descuentos específicos, pero que "seguramente fueron para clientes importantes".

Preguntas:

- a) ¿Qué tipo de control de aplicación (entrada, procesamiento o salida) es deficiente en este caso y por qué? (2 puntos)
- b) Además del control de aplicación, ¿qué control general de TI es claramente deficiente o inexistente, y cuál es la consecuencia directa de esta deficiencia para la investigación de Carlos? (3 puntos)
- c) ¿Qué principio ético fundamental debe guiar a Carlos en el manejo de esta situación, especialmente cuando recibe respuestas evasivas del gerente comercial? (2 puntos)
- d) Considerando los hallazgos, ¿cuál debería ser la recomendación principal de Carlos en su informe de auditoría para corregir el problema de raíz? (3 puntos)

Sección 5: Ensayo Corto (15 puntos)

Instrucciones: Redacta un ensayo de una página (aproximadamente 300-400 palabras) que responda a la siguiente pregunta. Se evaluará la claridad de la idea, la estructura del texto, la fundamentación en los conceptos de la unidad y la capacidad de análisis crítico.

Tema del ensayo: "En el contexto nicaragüense actual, con la creciente digitalización de los servicios (banca en línea, facturación electrónica, gobierno electrónico) y la reciente aprobación de la Ley de Protección de Datos Personales (Ley 1042), ¿consideras que el rol del auditor de TI es importante para las organizaciones? Justifica tu respuesta, explicando al menos tres razones fundamentales por las que su labor es clave para el éxito y la sostenibilidad de una empresa o institución pública en Nicaragua."

Guía para la estructura del ensayo:

- Introducción (3 puntos): Presenta tu tesis (tu postura clara sobre la importancia del auditor de TI en Nicaragua).
- Desarrollo (9 puntos): Expón al menos tres argumentos sólidos, cada uno respaldado por conceptos de la unidad (tipos de auditoría, control interno, normas, funciones del auditor, etc.). Utiliza ejemplos concretos del contexto nicaragüense (pueden ser los vistos en clase o imaginarios pero realistas).
- Conclusión (3 puntos): Resume tu postura y ofrece una reflexión final sobre el futuro de la profesión en el país.

Criterios de evaluación

SECCIÓN	PUNTAJE	CRITERIOS DE EVALUACIÓN
SECCIÓN 1: SELECCIÓN MÚLTIPLE	20 puntos	Respuestas correctas según la clave.
SECCIÓN 2: TÉRMINOS PAREADOS	15 puntos	Correspondencia correcta entre conceptos y descripciones.
SECCIÓN 3: DESARROLLO CORTO	20 puntos	Claridad, precisión y fundamentación en los conceptos de la unidad (4 puntos cada pregunta).
SECCIÓN 4: CASOS PRÁCTICOS	30 puntos	Capacidad para aplicar los conceptos a situaciones concretas, justificación de las respuestas, identificación correcta de problemas y soluciones (10 puntos cada caso).
SECCIÓN 5: ENSAYO CORTO	15 puntos	Claridad de la tesis, estructura del ensayo, solidez de los argumentos (fundamentados en la unidad), ejemplos contextualizados, y conclusión reflexiva.

- Contraloría General de la República de Nicaragua. (2023). *Normas de Auditoría Gubernamental de Nicaragua (NAGUN) - Actualización 2023*.
- Gómez Vieites, Á. (2020). Auditoría de seguridad informática (2ª ed.). Ra-Ma.
- Hernández Hernández, E. (2018). Auditoría en tecnologías de información: Enfoque metodológico y práctico (3ª ed.). Alfaomega.
- ISACA. (2019). COBIT 2019: Marco de referencia para el gobierno y la gestión de la información y la tecnología.
- ISO/IEC. (2022). *ISO/IEC 27001:2022 - Tecnología de la información - Técnicas de seguridad - Sistemas de Gestión de Seguridad de la Información (SGSI) - Requisitos*.
- Muñoz Razo, C. (2015). Auditoría en tecnologías de información (2ª ed.). Pearson Educación.
- Piattini, M. G., Del Peso, E., & Peso, M. del. (2020). Auditoría de tecnologías y sistemas de información (3ª ed.). Ra-Ma.
- Sánchez, L., & Fernández, C. (2021). Ciberseguridad y privacidad en la era digital: Cumplimiento normativo y auditoría. Wolters Kluwer.

- **Ambiente de Control:** Conjunto de normas, procesos y estructuras que constituyen la base sobre la que se sustenta el control interno en una organización. Incluye la integridad, los valores éticos, la filosofía de la dirección, la estructura organizativa y la asignación de autoridad y responsabilidad. Es el primer componente del modelo COSO.
- **ARESEP:** Autoridad Reguladora de los Servicios Públicos de Nicaragua. Ente estatal que, entre otras funciones, actúa como autoridad de aplicación de la Ley No. 1042 de Protección de Datos Personales, supervisando el cumplimiento de esta normativa por parte de las organizaciones.
- **Auditor de TI:** Profesional independiente y objetivo que posee los conocimientos, habilidades y experiencia necesarios para examinar, evaluar y emitir una opinión sobre los sistemas de información, la infraestructura tecnológica, los procesos de TI y los controles internos relacionados, con el fin de determinar si son adecuados, eficaces y están alineados con los objetivos del negocio.
- **Auditoría:** Proceso sistemático, objetivo e independiente que consiste en obtener y evaluar evidencias para determinar si las actividades, eventos, procesos o información de una entidad cumplen con criterios, normas o requisitos establecidos, comunicando los resultados mediante un informe.
- **Auditoría de Cumplimiento en TI:** Tipo de auditoría que verifica que las operaciones y procedimientos de TI de una organización se ajustan a las normas, leyes, regulaciones y políticas establecidas, tanto internas como externas (ej. Ley 1042, normas SIBOIF, NAGUN).
- **Auditoría de Sistemas o Aplicaciones:** Tipo de auditoría de TI que se centra en una aplicación de software específica para verificar su correcto funcionamiento, la precisión de sus procesamientos y la existencia de controles adecuados de entrada, procesamiento y salida.

- Auditoría Forense Informática: Rama especializada de la auditoría de TI que se activa generalmente después de un incidente de seguridad con posibles implicaciones legales. Su objetivo es investigar, recolectar, preservar y analizar evidencias digitales que sean admisibles en un proceso judicial, manteniendo una estricta cadena de custodia.
- Cadena de Custodia: Proceso documentado y controlado que garantiza la integridad y autenticidad de la evidencia digital desde su recolección hasta su presentación en un juicio, asegurando que no ha sido alterada, dañada o manipulada.
- Certificación CISA (Certified Information Systems Auditor): Certificación profesional más reconocida a nivel mundial para auditores de TI, emitida por ISACA. Acredita conocimientos y competencias en auditoría de sistemas de información, control y seguridad.
- COBIT (Control Objectives for Information and Related Technologies): Marco de referencia desarrollado por ISACA para el gobierno y la gestión de las TI empresariales. Proporciona objetivos de control, buenas prácticas y modelos de madurez, siendo la herramienta fundamental para los auditores de TI. La versión más reciente es COBIT 2019.
- COBIT 2019: Versión más reciente del marco COBIT, publicada en 2019. Introduce un enfoque más flexible y personalizable, basado en "factores de diseño" que permiten adaptar el sistema de gobierno a las necesidades específicas de cada organización.
- Controles de Aplicación: Controles integrados dentro de las aplicaciones de software para garantizar la integridad, precisión y validez del procesamiento de datos. Se clasifican en controles de entrada, procesamiento y salida.
- Controles Generales de TI (ITGC): Controles que aplican a todas las áreas de TI de la organización, independientemente de la aplicación específica. Incluyen: gestión de seguridad lógica, gestión de cambios, gestión de operaciones, continuidad del negocio, seguridad física, entre otros.

- Control Interno: Proceso integral, dinámico y continuo, diseñado y ejecutado por la dirección, la gerencia y el personal de una entidad, para proporcionar un grado de seguridad razonable en cuanto a la consecución de los objetivos de la organización en materia de eficacia y eficiencia de las operaciones, confiabilidad de la información y cumplimiento de leyes y regulaciones.
- COSO (Committee of Sponsoring Organizations of the Treadway Commission): Marco de referencia para el diseño, implementación y evaluación de sistemas de control interno. Sus cinco componentes son: Ambiente de Control, Evaluación de Riesgos, Actividades de Control, Información y Comunicación, y Supervisión y Monitoreo.
- Criterio de Auditoría: Conjunto de políticas, normas, estándares, leyes o requisitos contra los cuales el auditor compara la evidencia obtenida para emitir un juicio profesional. Por ejemplo, ISO 27001, PCI DSS, NAGUN.
- Debilidad de Control: Deficiencia en el diseño u operación de un control que impide que este funcione como se espera. Puede clasificarse como debilidad material, deficiencia significativa o deficiencia de control, según su severidad.
- Escepticismo Profesional: Actitud del auditor que implica una mente inquisidora y una evaluación crítica de la evidencia, sin asumir automáticamente que la gerencia es honesta o que los controles funcionan. Implica cuestionar, profundizar y no dar nada por sentado.
- Estándar: Documento que establece especificaciones técnicas, métodos de prueba, terminología o directrices para un producto, proceso o servicio. Puede ser desarrollado por organismos de estandarización o consorcios industriales (ej. PCI DSS, IEEE 802.11).
- Evidencia Digital: Cualquier información de valor probatorio almacenada o transmitida en formato digital que puede ser utilizada en un proceso judicial. Incluye archivos, correos electrónicos, logs, metadatos, entre otros.
- Independencia del Auditor: Principio fundamental que exige que el auditor mantenga una actitud imparcial, libre de sesgos, conflictos de interés o

influencias que puedan afectar su juicio profesional. Puede ser independencia de pensamiento y de apariencia.

- ISACA (Information Systems Audit and Control Association): Organización internacional líder en el desarrollo de estándares, guías y certificaciones para la auditoría de TI, el gobierno de TI y la ciberseguridad. Emite las certificaciones CISA, CISM, CRISC y CGEIT.
- ISO/IEC 27001: Norma internacional certificable que especifica los requisitos para establecer, implementar, mantener y mejorar un Sistema de Gestión de Seguridad de la Información (SGSI). Es la norma más importante para la seguridad de la información a nivel mundial. La versión más reciente es ISO 27001:2022.
- ITIL (Information Technology Infrastructure Library): Marco de referencia más utilizado a nivel mundial para la gestión de servicios de TI. Se enfoca en alinear los servicios de TI con las necesidades del negocio, mejorando la eficiencia y la calidad del servicio. La versión más reciente es ITIL 4.
- Log (Registro de Auditoría): Registro cronológico de eventos, transacciones o accesos a un sistema, aplicación o dispositivo. Los logs son fundamentales para la auditoría de TI, ya que permiten reconstruir actividades y detectar irregularidades.
- Modelo (o Marco de Referencia): Conjunto de buenas prácticas, principios y procesos agrupados de manera estructurada, que sirve como guía o referencia para la gestión de áreas específicas. No es obligatorio, sino voluntario (ej. COBIT, ITIL, COSO).
- NAGUN (Normas de Auditoría Gubernamental de Nicaragua): Normas emitidas por la Contraloría General de la República (CGR) de cumplimiento obligatorio para todas las entidades del sector público en Nicaragua. Establecen los lineamientos para la práctica de la auditoría gubernamental, incluyendo disposiciones para la auditoría de sistemas de información.
- NIST (National Institute of Standards and Technology): Agencia del Departamento de Comercio de Estados Unidos que publica estándares y guías

técnicas, muchas de ellas referentes mundiales en ciberseguridad. Publicaciones clave: NIST Cybersecurity Framework (CSF), NIST SP 800-53.

- Norma: Documento establecido por consenso y aprobado por un organismo reconocido (como ISO), que proporciona reglas, directrices o características para que las actividades o sus resultados sean óptimos. Su cumplimiento puede ser voluntario u obligatorio (ej. ISO 27001).
- Objetividad: Principio ético del auditor que exige no permitir que sesgos, conflictos de interés o influencias indebidas prevalezcan sobre su juicio profesional.
- PCI DSS (Payment Card Industry Data Security Standard): Estándar de seguridad creado por el Consejo de Normas de Seguridad de la Industria de Tarjetas de Pago (PCI SSC), de cumplimiento obligatorio para cualquier organización que almacene, procese o transmita datos de titulares de tarjetas. Consta de 6 objetivos y 12 requisitos.
- Prueba de Cumplimiento (o de Controles): Procedimiento de auditoría mediante el cual el auditor verifica que un control existe, está diseñado adecuadamente y opera de manera efectiva. Por ejemplo, revisar una muestra de solicitudes de acceso para verificar que todas fueron autorizadas.
- Prueba Sustantiva: Procedimiento de auditoría dirigido a detectar errores o irregularidades directamente en los datos o transacciones, generalmente cuando los controles son débiles o como complemento a las pruebas de cumplimiento.
- Segregación de Funciones: Principio fundamental de control interno que consiste en dividir las responsabilidades clave de un proceso entre diferentes personas para reducir el riesgo de errores o fraudes. En TI, una misma persona no debe tener todas las capacidades para cometer y ocultar un fraude.
- Seguridad Física: Conjunto de medidas de protección del entorno físico donde residen los activos tecnológicos: control de acceso a instalaciones,

condiciones ambientales, protección contra incendios, energía eléctrica y vigilancia.

- Seguridad Lógica: Conjunto de controles de acceso a la información a nivel de sistemas, aplicaciones y datos: gestión de usuarios y contraseñas, permisos de acceso, autenticación, cifrado, firewalls, IDS/IPS.
- SGSI (Sistema de Gestión de Seguridad de la Información): Conjunto de políticas, procedimientos, controles y procesos establecidos por una organización para gestionar y proteger sus activos de información, basado en un enfoque de gestión de riesgos. La norma ISO 27001 establece los requisitos para implementar un SGSI.
- SIBOIF (Superintendencia de Bancos y de Otras Instituciones Financieras): Ente regulador del sistema financiero nicaragüense. Emite normas, resoluciones y circulares de cumplimiento obligatorio para bancos, financieras, cooperativas supervisadas, etc., incluyendo normativas específicas sobre gestión de riesgos de TI y seguridad de la información.